TRƯỜNG ĐẠI HỌC ……

KHOA ……

ĐỒ ÁN CUỐI KỲ

Học phần: BẢO MẬT MẠNG MÁY TÍNH VÀ HỆ THỐNG

Hướng 1 – Security: Thiết kế hệ thống an toàn

ĐỀ TÀI

SAFEPAY GUARD

HỆ THỐNG XÁC MINH VÀ PHÊ DUYỆT LỆNH CHUYỂN TIỀN CHỐNG GIẢ MẠO (DEEPFAKE, BEC) CHO DOANH NGHIỆP VỪA VÀ NHỎ

STT	Họ và tên	MSSV
1	……	……
2	……	……
3	……	……
4	……	……

Giảng viên hướng dẫn: ……

Tháng 10/2026

MỤC LỤC

CHƯƠNG 1. GIỚI THIỆU BÀI TOÁN 7
1.1. Bối cảnh 7
1.2. Phát biểu bài toán 7
1.3. Đối tượng sử dụng 8
1.4. Phạm vi và giả định 8
1.5. Mục tiêu an toàn 8
1.6. Đối chiếu với yêu cầu đề bài 9
CHƯƠNG 2. TÀI SẢN, TÁC NHÂN VÀ PHÂN TÍCH RỦI RO 10
2.1. Tài sản cần bảo vệ 10
2.2. Tác nhân đe dọa 10
2.3. Phân tích mối đe dọa theo STRIDE 10
2.4. Danh sách rủi ro và ma trận rủi ro 11
CHƯƠNG 3. THIẾT KẾ KIẾN TRÚC VÀ LUỒNG DỮ LIỆU 12
3.1. Kiến trúc tổng thể 12
3.2. Ranh giới tin cậy 13
3.3. Luồng dữ liệu phê duyệt lệnh chuyển tiền 13
3.4. Luồng xử lý yêu cầu đổi số tài khoản 14
3.5. Mô hình dữ liệu 14
3.6. Vòng đời của một lệnh 15
CHƯƠNG 4. CÁC CƠ CHẾ BẢO VỆ 16
4.1. Nguyên tắc thiết kế 16
4.2. Xác thực đa yếu tố gắn với thiết bị 16
4.3. Chữ ký số giao dịch (What You See Is What You Sign) 17
4.4. Chính sách phê duyệt theo số tiền và rủi ro 17
4.5. Bộ chấm điểm rủi ro 17
4.6. Xác minh ngoài băng (gọi lại) 18
4.7. Sổ đăng ký nhà cung cấp và thời gian chờ 18

4.8. Toàn vẹn dữ liệu và kiểm tra lại khi thực thi 18
4.9. Nhật ký kiểm toán chống sửa đổi 18
4.10. Khoá khẩn cấp 19
4.11. Ánh xạ rủi ro – biện pháp 19
CHƯƠNG 5. HỆ THỐNG DỰA VÀO ĐÂU ĐỂ TIN, KIỂM CHỨNG HOẶC TỪ CHỐI THÔNG TIN 20
5.1. Phân loại nguồn thông tin 20
5.2. Quy trình ra quyết định 21
5.3. Tình huống 1 – Cuộc gọi video deepfake của Giám đốc 21
5.4. Tình huống 2 – Email giả nhà cung cấp đổi số tài khoản (BEC) 22
5.5. Tình huống 3 – Tài khoản bị chiếm quyền 22
5.6. Tình huống 4 – Dữ liệu bị chỉnh sửa 23
5.7. Tình huống 5 – Hình ảnh giả mạo (ảnh hoá đơn, ảnh chụp màn hình) 23
5.8. Đầu vào thật nhưng bị sử dụng sai ngữ cảnh 23
5.9. Tổng hợp theo bốn dạng đầu vào không đáng tin 24
CHƯƠNG 6. PROTOTYPE 25
6.1. Công nghệ sử dụng 25
6.2. Cấu trúc mã nguồn 25
6.3. Cài đặt và chạy 25
6.4. Kịch bản demo đề xuất khi thuyết trình 26
6.5. Giới hạn của prototype 26
CHƯƠNG 7. KIỂM THỬ 27
7.1. Phương pháp 27
7.2. Bộ test case và kết quả 27
7.3. Tổng hợp kết quả 28
7.4. Truy vết rủi ro – test case 29
CHƯƠNG 8. PHÂN TÍCH TRADE-OFF 30
8.1. An toàn và tiện lợi: phê duyệt nhiều lớp, gọi lại, thời gian chờ 30
8.2. An toàn và chi phí 30

8.3. An toàn và riêng tư 31
8.4. Khả năng triển khai 31
8.5. Tổng hợp 31
CHƯƠNG 9. HẠN CHẾ, HƯỚNG PHÁT TRIỂN VÀ KẾT LUẬN 32
9.1. Hạn chế 32
9.2. Hướng phát triển 32
9.3. Kết luận 32
TÀI LIỆU THAM KHẢO 34
PHỤ LỤC. KẾT QUẢ CHẠY KỊCH BẢN DEMO 35

DANH MỤC TỪ VIẾT TẮT

Viết tắt	Ý nghĩa
BEC	Business Email Compromise – lừa đảo qua email doanh nghiệp (giả danh lãnh đạo/nhà cung cấp)
NCC	Nhà cung cấp (người thụ hưởng)
STK	Số tài khoản ngân hàng
KTT / GĐ / PGĐ	Kế toán trưởng / Giám đốc / Phó Giám đốc
OTP / TOTP	Mật khẩu dùng một lần / OTP theo thời gian (RFC 6238)
MFA	Xác thực đa yếu tố
HMAC	Mã xác thực thông điệp dựa trên hàm băm
Ed25519	Lược đồ chữ ký số trên đường cong Edwards (RFC 8032)
WYSIWYS	What You See Is What You Sign – ký đúng cái được hiển thị
SoD	Separation of Duties – tách biệt nhiệm vụ (maker–checker)
OOB	Out-of-band – xác minh qua kênh độc lập (gọi lại)
HSM / KMS	Thiết bị/ dịch vụ quản lý khoá mật mã
WORM	Write Once Read Many – lưu trữ ghi một lần
STRIDE	Spoofing, Tampering, Repudiation, Information disclosure, Denial of service, Elevation of privilege

TÓM TẮT

Lừa đảo chuyển tiền bằng cách giả danh lãnh đạo hoặc nhà cung cấp – qua email, tin nhắn và ngày càng nhiều qua giọng nói, video giả mạo bằng AI (deepfake) – là một trong những hình thức tội phạm mạng gây thiệt hại lớn nhất cho doanh nghiệp. Điểm chung của các vụ việc là: nhân viên kế toán nhận được một yêu cầu "trông có vẻ thật" và thực hiện theo, vì quy trình nội bộ mặc định tin vào hình ảnh, giọng nói, địa chỉ email hay chữ ký trên văn bản.

Đồ án thiết kế SafePay Guard – một hệ thống phê duyệt lệnh chuyển tiền cho doanh nghiệp vừa và nhỏ, được xây dựng trên nguyên tắc: mọi thông tin đến từ bên ngoài chỉ là lời khẳng định chưa được xác minh. Hệ thống không cố "phát hiện deepfake", mà làm cho deepfake trở nên vô dụng: tiền chỉ được chuyển khi có chữ ký số Ed25519 từ thiết bị đã đăng ký của đúng những người có thẩm quyền, trên đúng nội dung lệnh, tới đúng tài khoản trong sổ đăng ký đã xác minh; các lệnh rủi ro cao còn phải được gọi lại xác minh qua số điện thoại lấy từ danh bạ nội bộ.

Báo cáo trình bày tài sản cần bảo vệ, tác nhân đe dọa, phân tích rủi ro theo STRIDE, kiến trúc và luồng dữ liệu, các cơ chế bảo vệ (MFA gắn thiết bị, chữ ký giao dịch, phê duyệt theo rủi ro, xác minh ngoài băng, thời gian chờ khi đổi tài khoản, HMAC toàn vẹn, nhật ký chuỗi băm), cách hệ thống xử lý khi đầu vào bị giả mạo hoặc tài khoản bị chiếm quyền, và phân tích trade-off ngắn hạn – dài hạn. Prototype viết bằng Python/Flask kèm 15 kịch bản demo và 33 test case (38 lượt kiểm thử) – tất cả đều đạt.

Từ khoá: BEC, deepfake, chữ ký giao dịch, xác thực đa yếu tố, maker–checker, xác minh ngoài băng, nhật ký chống sửa đổi.

CHƯƠNG 1. GIỚI THIỆU BÀI TOÁN

1.1. Bối cảnh

Business Email Compromise (BEC) là hình thức kẻ gian mạo danh lãnh đạo, đối tác hoặc nhà cung cấp để yêu cầu nhân viên chuyển tiền hoặc đổi số tài khoản nhận tiền. Theo báo cáo Internet Crime Report 2023 của FBI (IC3), BEC gây thiệt hại được ghi nhận khoảng 2,9 tỷ USD chỉ trong một năm tại Mỹ, đứng thứ hai trong các loại tội phạm mạng về giá trị thiệt hại.

Sự phát triển của AI tạo sinh làm vấn đề nghiêm trọng hơn: giọng nói và khuôn mặt có thể được giả lập chỉ từ vài đoạn video công khai. Đầu năm 2024, một nhân viên tài chính của tập đoàn kỹ thuật Arup tại Hồng Kông đã chuyển khoảng 25 triệu USD sau một cuộc họp video mà tất cả "đồng nghiệp" khác, kể cả giám đốc tài chính, đều là deepfake. Tại Việt Nam, cơ quan công an nhiều lần cảnh báo thủ đoạn giả danh lãnh đạo qua Zalo, Facebook và cuộc gọi video deepfake để yêu cầu kế toán chuyển tiền gấp.

Các vụ việc này có chung một điểm yếu về thiết kế: quy trình chuyển tiền tin vào những thứ "trông có vẻ thật" – giọng nói quen, khuôn mặt quen, địa chỉ email gần giống, logo trên hoá đơn – trong khi tất cả đều có thể bị làm giả với chi phí ngày càng thấp.

1.2. Phát biểu bài toán

Thiết kế một hệ thống giúp doanh nghiệp vừa và nhỏ (SME) kiểm soát việc chuyển tiền ra ngoài sao cho:

- Một yêu cầu chuyển tiền giả mạo (email, chat, ảnh chụp chứng từ, cuộc gọi thoại/video deepfake) không thể dẫn tới việc tiền bị chuyển đi, kể cả khi nhân viên tiếp nhận tin rằng yêu cầu là thật.
- Yêu cầu đổi số tài khoản của nhà cung cấp không thể được áp dụng chỉ dựa trên một email/văn bản.
- Khi một tài khoản người dùng (mật khẩu, OTP, phiên đăng nhập, thậm chí điện thoại của một người duyệt) bị chiếm, kẻ gian vẫn không tự chuyển tiền được, và thiệt hại có thể được khoanh vùng.
- Mọi chỉnh sửa trái phép đối với lệnh hoặc nhật ký đều bị phát hiện; mọi hành động đều truy vết được tới người thực hiện.
- Quy trình vẫn đủ thuận tiện cho các khoản thanh toán thường ngày, rủi ro thấp.

1.3. Đối tượng sử dụng

Hệ thống hướng tới doanh nghiệp 20–200 nhân sự, có bộ phận kế toán 2–5 người và chuyển tiền cho nhà cung cấp hằng tuần qua Internet Banking doanh nghiệp. Đây là nhóm đối tượng chịu rủi ro BEC cao vì thường không có bộ phận an ninh riêng và quy trình phê duyệt chủ yếu dựa vào tin nhắn/điện thoại.

Bảng 1.1. Người dùng hệ thống và quyền hạn

Vai trò	Mô tả	Quyền chính
Kế toán viên (Maker)	Tiếp nhận yêu cầu, lập lệnh chuyển tiền	Tạo lệnh, tiếp nhận yêu cầu đổi STK, gửi lệnh đã duyệt sang ngân hàng
Kế toán trưởng (Checker)	Kiểm soát chứng từ	Duyệt/từ chối lệnh, gọi lại xác minh, duyệt đổi STK
Giám đốc / Phó GĐ	Người có thẩm quyền cao nhất	Duyệt lệnh lớn hoặc rủi ro cao
Quản trị hệ thống	Bộ phận IT	Duyệt thiết bị mới, khoá khẩn cấp tài khoản; KHÔNG được tạo/duyệt lệnh
Kiểm toán viên (ngoài)	Kiểm toán nội bộ/độc lập	Nhận mốc neo nhật ký, đối chiếu định kỳ

1.4. Phạm vi và giả định

- **Trong phạm vi:** quy trình từ lúc doanh nghiệp nhận một yêu cầu chuyển tiền/đổi số tài khoản đến lúc lệnh được gửi sang ngân hàng; quản lý người dùng, thiết bị, sổ đăng ký nhà cung cấp, nhật ký kiểm toán.
- **Ngoài phạm vi:** an ninh nội bộ của ngân hàng; phát hiện mã độc trên máy trạm; chống tấn công từ chối dịch vụ; phát hiện deepfake bằng AI (xem phân tích lý do ở Chương 8).
- **Giả định:** sổ đăng ký nhà cung cấp và danh bạ nội bộ được thiết lập đúng khi ký hợp đồng/khi nhân viên vào làm (đối chiếu giấy tờ, gặp trực tiếp) – đây là "mỏ neo tin cậy" (trust anchor) của toàn hệ thống; điện thoại người duyệt có khoá màn hình và vùng lưu khoá an toàn (Secure Enclave/StrongBox); máy chủ được vận hành bởi bên tin cậy.

1.5. Mục tiêu an toàn

Bảng 1.2. Mục tiêu an toàn

Mục tiêu	Ý nghĩa trong hệ thống
Xác thực nguồn gốc (Authenticity)	Biết chắc ai thực sự yêu cầu/phê duyệt – không dựa trên lời tự xưng
Toàn vẹn (Integrity)	Số tiền, STK, nội dung lệnh không thể bị sửa sau khi được duyệt mà không bị phát hiện
Chống chối bỏ (Non-	Mỗi phê duyệt là một chữ ký số gắn với một thiết bị và một người cụ

Mục tiêu	Ý nghĩa trong hệ thống
repudiation)	thể
Truy vết (Accountability)	Mọi hành động, kể cả các lần bị từ chối, đều được ghi nhật ký chống sửa đổi
Bí mật (Confidentiality)	Mật khẩu băm Argon2id, khoá riêng không rời thiết bị, khoá HMAC nằm trong HSM/KMS
Sẵn sàng (Availability)	Lệnh thường ngày rủi ro thấp chỉ cần 1 người duyệt trên điện thoại

1.6. Đối chiếu với yêu cầu đề bài

Bảng dưới đây chỉ ra nơi mỗi yêu cầu của đề bài (Hướng 1 – Security) được trả lời trong báo cáo và trong các sản phẩm kèm theo.

Bảng 1.3. Đối chiếu yêu cầu đề bài – vị trí trả lời

Yêu cầu của đề bài	Vị trí trong báo cáo	Sản phẩm kèm theo
Bài toán cụ thể, đối tượng sử dụng rõ ràng, phạm vi vừa phải	1.2, 1.3, 1.4	–
Hệ thống bảo vệ tài sản / dữ liệu gì	2.1	–
Ai sử dụng, ai có thể tấn công hoặc lạm dụng	1.3, 2.2	–
Có những rủi ro, cách tấn công nào	2.3 (STRIDE), 2.4	so_do/05_ma_tran_rui_ro.png
Kiến trúc và luồng dữ liệu	Chương 3	so_do/01, 02, 04
Dùng cơ chế nào để bảo vệ; cơ chế phù hợp với rủi ro	Chương 4, bảng ánh xạ ở 4.11	prototype/safepay/
Hệ thống dựa vào đâu để tin, kiểm chứng hoặc từ chối thông tin	Chương 5 (5.1, 5.2)	so_do/03_co_che_quyet_dinh_tin_cay.png
Tình huống đầu vào bị giả mạo, chỉnh sửa, đánh cắp hoặc sử dụng sai ngữ cảnh	5.3 – 5.8, bảng tổng hợp ở 5.9	KB03 – KB15
Xử lý khi tài khoản bị chiếm quyền	5.5	so_do/06_phong_thu_nhieu_lop.png
Prototype hoặc mô phỏng	Chương 6	prototype/ (web Flask + 15 kịch bản)
Test case cho tình huống bình thường và tình huống rủi ro	Chương 7	prototype/tests/, ket_qua_kiem_thu/
Ít nhất một trade-off, xét ngắn hạn và dài hạn	Chương 8 (5 trade-off)	–
Slide thuyết trình và demo	6.4 (kịch bản demo)	Slide_DoAn_Huong1_SafePayGuard.pptx

CHƯƠNG 2. TÀI SẢN, TÁC NHÂN VÀ PHÂN TÍCH RỦI RO

2.1. Tài sản cần bảo vệ

Bảng 2.1. Tài sản cần bảo vệ

Mã	Tài sản / dữ liệu	Thuộc tính cần bảo vệ	Mức độ
A1	Tiền trong tài khoản doanh nghiệp (tài sản cuối cùng)	Toàn vẹn của quyết định chuyển tiền	Rất cao
A2	Sổ đăng ký nhà cung cấp: tên, STK, MST, SĐT đã xác minh	Toàn vẹn, xác thực nguồn gốc	Rất cao
A3	Lệnh chuyển tiền: người thụ hưởng, STK, số tiền, nội dung	Toàn vẹn, chống chối bỏ	Rất cao
A4	Thông tin xác thực: mật khẩu, bí mật TOTP, khoá riêng thiết bị	Bí mật	Rất cao
A5	Khoá máy chủ: khoá HMAC toàn vẹn, khoá HMAC nhật ký	Bí mật	Cao
A6	Phiên đăng nhập (token)	Bí mật, thời hạn	Cao
A7	Danh bạ nội bộ (SĐT lãnh đạo để gọi lại)	Toàn vẹn	Cao
A8	Nhật ký kiểm toán	Toàn vẹn, đầy đủ	Cao
A9	Lịch sử thanh toán (dùng cho chấm điểm rủi ro)	Toàn vẹn, riêng tư	Trung bình

2.2. Tác nhân đe dọa

Bảng 2.2. Tác nhân đe dọa

Tác nhân	Động cơ	Năng lực / thủ đoạn
Nhóm lừa đảo BEC bên ngoài	Tài chính	Email giả mạo tên miền gần giống, chiếm hộp thư NCC thật, giả giọng/video lãnh đạo bằng AI, tạo áp lực "gấp, bí mật"
Kẻ tấn công chiếm tài khoản	Tài chính	Phishing trang đăng nhập giả lấy mật khẩu + OTP theo thời gian thực, credential stuffing, đánh cắp cookie phiên
Mã độc trên máy trạm	Tài chính	Sửa nội dung hiển thị trên trình duyệt, tráo số tiền/STK trước khi gửi
Nhân viên nội bộ gian lận	Tài chính, che giấu sai phạm	Tự lập – tự duyệt, sửa dữ liệu trực tiếp trong CSDL, xoá nhật ký
Quản trị viên lạm quyền	Tài chính	Thêm thiết bị cho người khác để ký thay
Kẻ trộm thiết bị	Cơ hội	Lấy được điện thoại của người duyệt

2.3. Phân tích mối đe dọa theo STRIDE

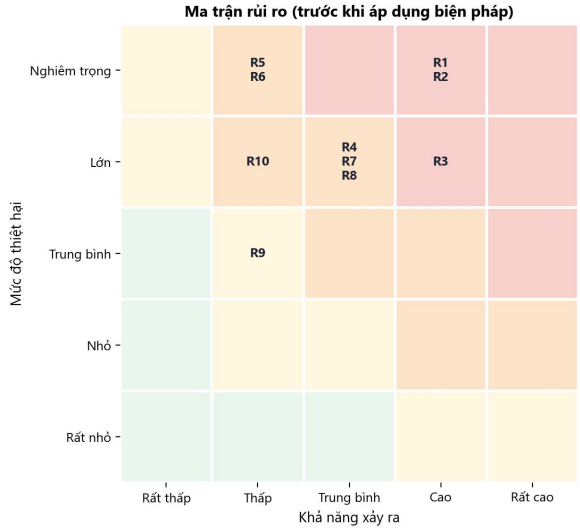
Bảng 2.3. Phân tích STRIDE

STRIDE	Mối đe dọa cụ thể	Biện pháp chính
Spoofing (giả mạo danh tính)	Deepfake giám đốc yêu cầu chuyển tiền; email giả NCC; đăng nhập bằng	Không chấp nhận danh tính tự xưng; chính người được nêu tên phải ký trên thiết bị;

STRIDE	Mối đe dọa cụ thể	Biện pháp chính
	mật khẩu lộ; khai báo mã thiết bị giả	MFA + chứng minh sở hữu khoá thiết bị; gọi lại số trong danh bạ
Tampering (sửa đổi)	Mã độc tráo số tiền; nội gián sửa STK trong CSDL; đổi STK NCC	Chữ ký Ed25519 trên nội dung chuẩn hoá; HMAC toàn vẹn; kiểm tra lại trước khi thực thi; quy trình đổi STK có gọi lại + 48h chờ
Repudiation (chối bỏ)	Người duyệt chối đã duyệt; kế toán chối đã gửi lệnh	Chữ ký số gắn thiết bị; nhật ký chuỗi băm + HMAC + mốc neo
Information disclosure (lộ lọt)	Lộ mật khẩu, bí mật TOTP, token phiên	Argon2id; khoá riêng không rời thiết bị; cookie HttpOnly/SameSite; phiên ngắn hạn
Denial of service	Khoá tài khoản người duyệt bằng cách cố tình đăng nhập sai	Khoá tạm thời 15 phút (không khoá vĩnh viễn) + cảnh báo; có nhiều người duyệt dự phòng
Elevation of privilege	Kế toán tự duyệt; admin tự thêm thiết bị cho mình; dùng 1 chữ ký 2 lần	Tách biệt nhiệm vụ; admin không có quyền nghiệp vụ; mỗi người 1 chữ ký/lệnh; danh sách chữ ký đã dùng

2.4. Danh sách rủi ro và ma trận rủi ro

Mỗi rủi ro được đánh giá theo khả năng xảy ra (KN) và mức độ thiệt hại (TH) trên thang 1–5, điểm rủi ro = KN × TH. Hai rủi ro cao nhất – giả danh lãnh đạo (R1) và email giả nhà cung cấp (R2) – chính là trọng tâm thiết kế của hệ thống.



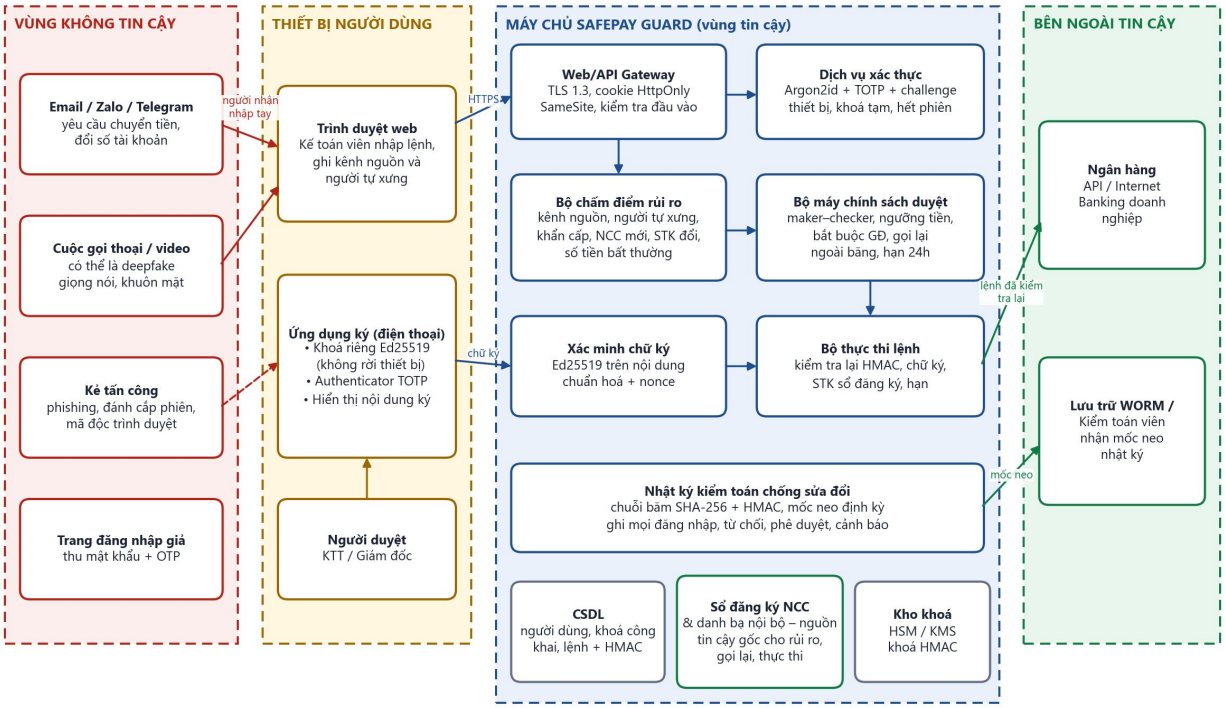
Mã	Rủi ro	KN	TH	Điểm
R1	Giả danh lãnh đạo (deepfake/giả giọng)	4	5	20
R2	Email giả NCC đổi số tài khoản (BEC)	4	5	20
R3	Lộ mật khẩu / phishing lấy OTP	4	4	16
R4	Đánh cắp phiên đăng nhập	3	4	12
R5	Mã độc tráo nội dung khi duyệt	2	5	10
R6	Nội gián sửa dữ liệu trong CSDL	2	5	10
R7	Người tạo lệnh tự duyệt / thông đồng	3	4	12
R8	Mất / bị chiếm điện thoại người duyệt	3	4	12
R9	Phát lại chữ ký / OTP	2	3	6
R10	Xoá / sửa nhật ký để che dấu vết	2	4	8

Hình 2.1. Ma trận rủi ro trước khi áp dụng biện pháp bảo vệ

CHƯƠNG 3. THIẾT KẾ KIẾN TRÚC VÀ LUỒNG DỮ LIỆU

3.1. Kiến trúc tổng thể

Hệ thống được chia thành bốn vùng với mức tin cậy khác nhau. Mũi tên đi từ vùng kém tin cậy sang vùng tin cậy hơn luôn phải đi qua một điểm kiểm soát (xác thực, chữ ký, chấm điểm rủi ro).



Hình 3.1. Kiến trúc tổng thể và các ranh giới tin cậy

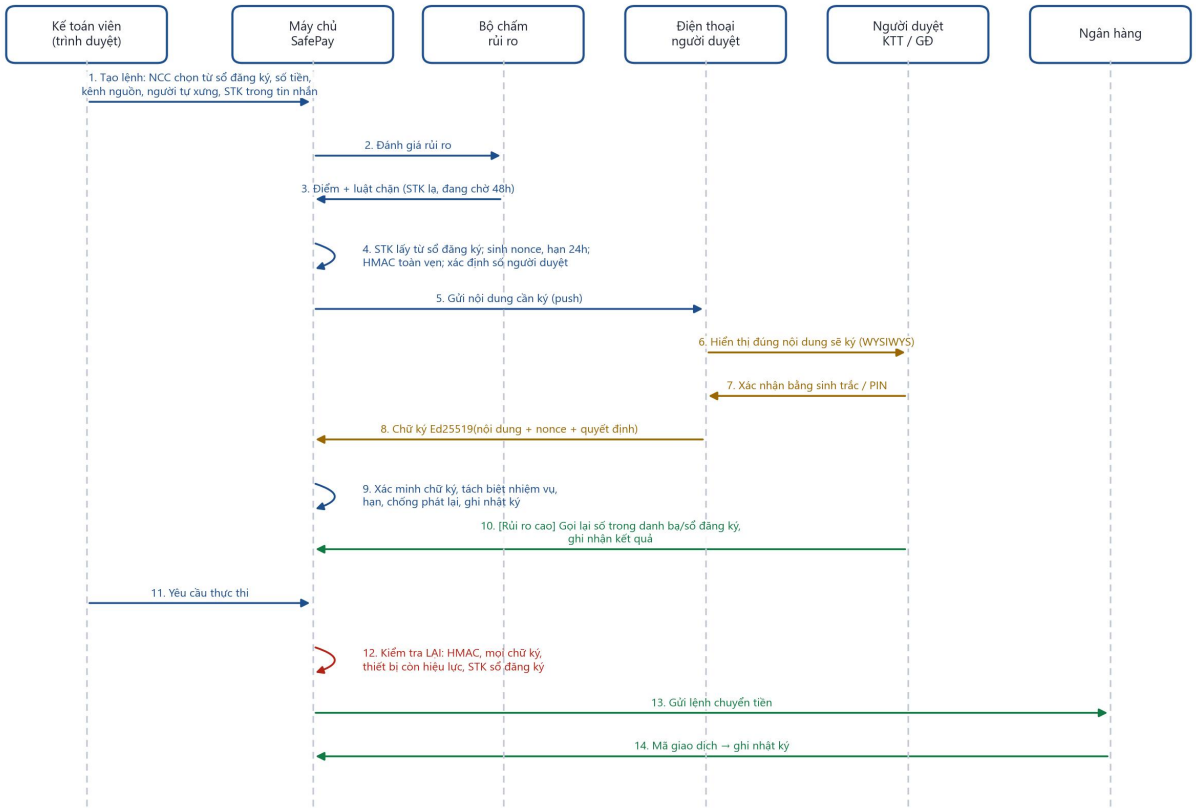
Bảng 3.1. Các thành phần chính

Thành phần	Chức năng	Tương ứng trong prototype
Web/API Gateway	Nhận yêu cầu qua HTTPS, quản lý cookie phiên, kiểm tra kiểu dữ liệu	app.py (Flask)
Dịch vụ xác thực	Argon2id, TOTP chống phát lại, challenge–response với khoá thiết bị, khoá tạm, hết phiên	core.py: start_login, login
Bộ chấm điểm rủi ro	Tính điểm theo luật, phát hiện luật chặn cứng	risk.py: assess
Bộ máy chính sách duyệt	Số người duyệt, bắt buộc GĐ, bắt buộc người tự xưng ký, gọi lại	core.py: create_payment, _approval_gaps
Xác minh chữ ký	Kiểm tra Ed25519 trên nội dung chuẩn hoá + nonce + quyết định	core.py: decide_payment
Bộ thực thi lệnh	Kiểm tra lại toàn bộ trước khi gửi ngân hàng	core.py: execute_payment
Nhật ký kiểm toán	Chuỗi băm SHA-256 + HMAC + mốc neo	audit.py
Ứng dụng ký trên điện thoại	Giữ khoá riêng, hiển thị nội dung, ký	device.py (mô phỏng)
Sổ đăng ký NCC & danh bạ	Nguồn tin cậy gốc cho STK và SĐT gọi lại	core.py: beneficiaries, users.phone

3.2. Ranh giới tin cậy

- **Vùng không tin cậy:** mọi kênh liên lạc bên ngoài (email, chat, điện thoại, video) và bất kỳ ai trên Internet. Dữ liệu từ đây chỉ được nhập vào hệ thống như một "lời khẳng định" kèm nhãn kênh nguồn.
- **Thiết bị người dùng:** tin cậy có điều kiện. Trình duyệt có thể nhiễm mã độc nên máy chủ không tin dữ liệu nó gửi lên; điện thoại được tin chỉ ở mức "chủ sở hữu khoá riêng đã xác nhận nội dung này", và có thể bị thu hồi bất cứ lúc nào.
- **Máy chủ:** vùng tin cậy, nhưng vẫn áp dụng nguyên tắc không tin dữ liệu đang lưu – lệnh được kiểm tra lại HMAC và chữ ký trước khi thực thi để chống nội gián sửa CSDL.
- **Bên ngoài tin cậy:** ngân hàng (nhận lệnh đã kiểm tra) và hệ thống lưu trữ WORM/kiểm toán viên (giữ mốc neo nhật ký, nằm ngoài quyền kiểm soát của quản trị viên).

3.3. Luồng dữ liệu phê duyệt lệnh chuyển tiền



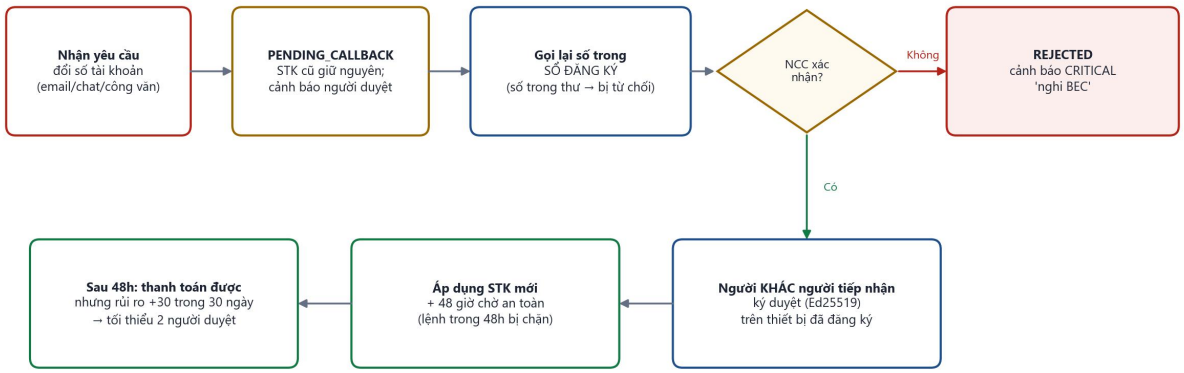
Hình 3.2. Luồng tạo – phê duyệt – thực thi một lệnh chuyển tiền

Ba điểm thiết kế quan trọng trong luồng:

- **Bước 4:** số tài khoản thụ hưởng luôn được lấy từ sổ đăng ký, không bao giờ lấy từ nội dung tin nhắn. Nếu tin nhắn chứa STK khác sổ đăng ký, lệnh bị chặn ngay.

- **Bước 6–8:** người duyệt xem nội dung trên điện thoại (kênh thứ hai, độc lập với trình duyệt có thể nhiễm mã độc) và ký đúng nội dung đó. Chữ ký bao gồm cả nonce, hạn và quyết định nên không thể dùng lại.
- **Bước 12:** khi thực thi, hệ thống không tin trạng thái "APPROVED" trong CSDL mà kiểm tra lại toàn bộ: HMAC, từng chữ ký, thiết bị chưa bị thu hồi, STK vẫn khớp sổ đăng ký và không trong thời gian chờ.

3.4. Luồng xử lý yêu cầu đổi số tài khoản



Hình 3.3. Luồng xử lý yêu cầu đổi số tài khoản nhà cung cấp

3.5. Mô hình dữ liệu

Bảng 3.2. Các thực thể dữ liệu

Thực thể	Trường chính	Ghi chú bảo mật
User	username, role, password_hash, totp_secret, phone, failed_logins, locked_until, last_totp_counter	Mật khẩu băm Argon2id; last_totp_counter chống phát lại OTP
Device	id, user_id, public_key, status (PENDING/ACTIVE/REVOKED)	Máy chủ chỉ lưu khoá công khai
Beneficiary	name, bank, account_no, tax_code, contact_phone, last_changed_at, cooling_until, payment_history	Nguồn tin cậy gốc; chỉ thay đổi qua quy trình đổi STK
AccountChange	beneficiary_id, new_account_no, source_channel, status, callback, nonce	Không có hiệu lực tới khi gọi lại + ký duyệt
PaymentRequest	beneficiary snapshot, amount, purpose, source_channel, claimed_by, nonce, expires_at, risk, required_approvals, require_director, require_callback, integrity_mac, approvals[]	HMAC trên toàn bộ trường quan trọng
Approval	user_id, device_id, decision, signature, payload_hash	Chữ ký Ed25519 trên payload chuẩn hoá
AuditEntry	seq, ts, event, actor, details, prev, hash, mac	Liên kết chuỗi băm + HMAC

3.6. Vòng đời của một lệnh

PENDING_APPROVAL → APPROVED → EXECUTED là luồng bình thường. Các trạng thái kết thúc khác: BLOCKED (luật chặn cứng, dữ liệu bị sửa, STK thay đổi), REJECTED (người duyệt từ chối hoặc người được gọi lại phủ nhận), EXPIRED (quá 24 giờ). Khi kích hoạt khoá khẩn cấp, lệnh APPROVED có chữ ký của người bị khoá được đưa về PENDING_APPROVAL.

CHƯƠNG 4. CÁC CƠ CHẾ BẢO VỆ

4.1. Nguyên tắc thiết kế

- **Không tin mặc định (zero trust đối với đầu vào):** giọng nói, khuôn mặt, email, tin nhắn chỉ là lời khẳng định; chỉ chữ ký mật mã và dữ liệu từ nguồn tin cậy gốc mới là bằng chứng.
- **Làm cho giả mạo trở nên vô dụng thay vì cố phát hiện giả mạo:** deepfake hoàn hảo đến đâu cũng không tạo ra được chữ ký Ed25519 từ điện thoại của Giám đốc.
- **Phòng thủ nhiều lớp:** mỗi lớp được thiết kế với giả định lớp trước đã bị vượt qua.
- **Tách biệt nhiệm vụ và đặc quyền tối thiểu:** người lập ≠ người duyệt; quản trị viên không có quyền nghiệp vụ.
- **Mặc định an toàn (fail-safe):** khi thiếu điều kiện hoặc có nghi ngờ, lệnh dừng lại chứ không được thông qua.
- **Kiểm soát toàn diện (complete mediation):** điều kiện được kiểm tra lại ở thời điểm thực thi, không dựa vào kết quả kiểm tra trước đó.

4.2. Xác thực đa yếu tố gắn với thiết bị

Đăng nhập yêu cầu đồng thời ba yếu tố: (1) mật khẩu – băm bằng Argon2id; (2) mã TOTP 6 số theo RFC 6238 – mỗi mã chỉ dùng được một lần nhờ lưu bộ đếm đã dùng gần nhất; (3) chứng minh sở hữu thiết bị – máy chủ gửi một challenge ngẫu nhiên, thiết bị ký bằng khoá riêng Ed25519; máy chủ kiểm tra bằng khoá công khai đã đăng ký.

Nhờ yếu tố thứ ba, trang đăng nhập giả mạo dù lấy được cả mật khẩu và OTP theo thời gian thực cũng không đăng nhập được từ máy của kẻ gian. Thêm thiết bị mới chỉ tạo ra thiết bị ở trạng thái PENDING, chủ tài khoản nhận cảnh báo, và quản trị viên phải duyệt sau khi xác minh trực tiếp – quản trị viên không được tự duyệt thiết bị của chính mình.

Bảng 4.1. Tham số xác thực

Tham số	Giá trị	Lý do
Số lần sai tối đa	5 lần → khoá 15 phút	Chặn dò OTP (10^6 khả năng) nhưng không cho phép kẻ gian khoá vĩnh viễn người duyệt
Cửa sổ TOTP	30 giây, chấp nhận lệch ±1 bước	Chịu được lệch đồng hồ điện thoại
Phiên	Hết hạn sau 15 phút không hoạt động, tối đa 8 giờ	Giảm giá trị của cookie bị đánh cắp
Challenge đăng nhập	Dùng 1 lần, hạn 120 giây	Chống phát lại chữ ký đăng nhập
Thông báo lỗi	Giống nhau cho sai tên đăng nhập / sai mật khẩu	Chống dò tài khoản tồn tại

4.3. Chữ ký số giao dịch (What You See Is What You Sign)

Mỗi quyết định duyệt/từ chối là một chữ ký Ed25519 trên bản JSON chuẩn hoá (khoá sắp xếp, không khoảng trắng) gồm:

```
{ "type": "PAYMENT_DECISION", "request_id": "PR-0001",
  "beneficiary_name": "...", "bank": "...", "account_no": "...",
  "amount": 40000000, "currency": "VND", "purpose": "...",
  "nonce": "<128 bit ngẫu nhiên>", "expires_at": 1793...,
  "decision": "APPROVE" }
```

Hệ quả: nếu mã độc tráo số tiền hiển thị trên màn hình, chữ ký sẽ không khớp với nội dung lệnh trên máy chủ và bị từ chối; chữ ký cho lệnh A không dùng được cho lệnh B (khác request_id, nonce); chữ ký "từ chối" không thể dùng làm "phê duyệt"; kẻ đánh cắp cookie phiên không có khoá riêng nên không ký được. Máy chủ còn lưu danh sách chữ ký đã dùng để chống phát lại. Ed25519 được chọn vì khoá ngắn (32 byte), ký nhanh, tất định và được hỗ trợ sẵn trong phần cứng bảo mật của điện thoại hiện đại.

4.4. Chính sách phê duyệt theo số tiền và rủi ro

Bảng 4.2. Chính sách phê duyệt

Điều kiện	Số người duyệt	Yêu cầu thêm
< 50 triệu, rủi ro THẤP	1	—
≥ 50 triệu	2	—
≥ 500 triệu	2	Bắt buộc có Giám đốc/Phó GĐ
Rủi ro TRUNG BÌNH (30–59 điểm)	2	—
Rủi ro CAO (≥ 60 điểm)	2	Bắt buộc Giám đốc + gọi lại xác minh ngoài băng
Yêu cầu tự xưng là của một lãnh đạo	theo các dòng trên	Chính người được nêu tên phải ký trên thiết bị của mình + gọi lại số trong danh bạ
STK trong tin nhắn khác sổ đăng ký / NCC đang trong 48h chờ / NCC chưa xác minh	—	CHẶN, cảnh báo CRITICAL

Mọi trường hợp đều áp dụng: người tạo lệnh không được duyệt; mỗi người chỉ ký một lần; lệnh hết hạn sau 24 giờ.

4.5. Bộ chấm điểm rủi ro

Bảng 4.3. Luật chấm điểm rủi ro

Luật	Điểm	Lý do
Yêu cầu đến từ kênh bên ngoài (email, chat, ảnh chụp, cuộc gọi thoại/video)	+25	Kênh có thể bị giả mạo hoàn toàn
Có người tự xưng là lãnh đạo qua kênh ngoài	+20	Thủ đoạn đặc trưng của BEC/deepfake CEO
Có yếu tố khẩn cấp / bí mật (đánh dấu hoặc từ khoá "gấp", "bí mật", "đừng báo ai"…)	+15	Kỹ thuật tạo áp lực tâm lý (social engineering)
Lần đầu thanh toán cho người thụ hưởng	+20	Không có lịch sử để đối chiếu

Luật	Điểm	Lý do
Số tiền > 3 lần trung bình các lần trước	+20	Bất thường về giá trị
STK người thụ hưởng đổi trong 30 ngày	+30	Giai đoạn rủi ro cao sau khi đổi tài khoản
Ngoài giờ làm việc (trước 8h, sau 18h, cuối tuần)	+10	Lúc ít người kiểm tra chéo

Bộ luật được thiết kế để thông tin từ bên ngoài chỉ có thể làm tăng điểm rủi ro, không bao giờ làm giảm. Điều này ngăn kẻ gian "tô vẽ" yêu cầu cho trông hợp lệ hơn. Cách tiếp cận dựa trên luật được chọn vì minh bạch, giải thích được cho người dùng và kiểm toán viên; có thể bổ sung mô hình học máy ở giai đoạn sau (Chương 9).

4.6. Xác minh ngoài băng (gọi lại)

Với lệnh rủi ro cao hoặc có người tự xưng, người duyệt phải gọi lại và ghi nhận kết quả. Hệ thống chỉ chấp nhận số điện thoại lấy từ danh bạ nội bộ (với lãnh đạo) hoặc sổ đăng ký (với nhà cung cấp); số do người yêu cầu đọc trong cuộc gọi hoặc ghi trong email bị từ chối. Nếu người được gọi lại phủ nhận, lệnh chuyển REJECTED và cảnh báo CRITICAL được phát ra. Người tạo lệnh không được tự ghi nhận kết quả gọi lại.

4.7. Sổ đăng ký nhà cung cấp và thời gian chờ

Kế toán chỉ có thể chọn người thụ hưởng trong sổ đăng ký; không có ô nhập STK tự do. Yêu cầu đổi STK đi qua quy trình riêng (Hình 3.3): gọi lại số trong sổ → người khác người tiếp nhận ký duyệt → STK mới có hiệu lực kèm 48 giờ chờ an toàn (mọi lệnh tới NCC này trong 48 giờ bị chặn) → trong 30 ngày tiếp theo, lệnh tới NCC này bị cộng 30 điểm rủi ro. Lệnh đã duyệt trước khi đổi STK sẽ bị chặn khi thực thi vì STK không còn khớp.

4.8. Toàn vẹn dữ liệu và kiểm tra lại khi thực thi

Khi tạo lệnh, máy chủ tính HMAC-SHA256 trên mọi trường quan trọng bằng khoá nằm trong HSM/KMS (không nằm trong CSDL). Kẻ có quyền ghi CSDL nhưng không có khoá sẽ không thể sửa lệnh mà không bị phát hiện. Trước khi gửi ngân hàng, bộ thực thi kiểm tra lại: HMAC, từng chữ ký với khoá công khai của thiết bị còn ACTIVE, các điều kiện phê duyệt, hạn, và đối chiếu STK với sổ đăng ký.

4.9. Nhật ký kiểm toán chống sửa đổi

Mỗi bản ghi chứa hash của bản ghi trước (hash chain, theo ý tưởng của Schneier & Kelsey) và HMAC của chính nó. Sửa một bản ghi làm hỏng hash; xoá/chèn bản ghi làm đứt chuỗi; giả mạo cả chuỗi cần khoá HMAC. Riêng việc cắt bỏ các bản ghi cuối không làm đứt chuỗi, nên định kỳ hệ thống gửi "mốc neo" (số thứ tự + hash cuối) ra

ngoài – lưu trữ WORM hoặc email tới kiểm toán viên – để phát hiện. Nhật ký ghi cả các lần bị từ chối (DENIED) và cảnh báo (ALERT), không chỉ các thao tác thành công.

4.10. Khoá khẩn cấp

Chủ tài khoản hoặc quản trị viên có thể kích hoạt khoá khẩn cấp: thu hồi mọi thiết bị, huỷ mọi phiên, và huỷ mọi chữ ký phê duyệt chưa được thực thi của người dùng đó. Các lệnh bị ảnh hưởng quay về PENDING_APPROVAL để người khác xem xét lại.

4.11. Ánh xạ rủi ro – biện pháp

Bảng 4.4. Ánh xạ rủi ro – biện pháp – rủi ro còn lại

Rủi ro	Biện pháp	Rủi ro còn lại
R1 Giả danh lãnh đạo	Người tự xưng phải tự ký; gọi lại số danh bạ; +45 điểm rủi ro; STK lạ → chặn	Thấp – trừ khi kẻ gian chiếm cả điện thoại lãnh đạo và kênh gọi lại
R2 Email giả NCC đổi STK	Không có ô nhập STK tự do; gọi lại số sổ đăng ký; ký duyệt; 48h chờ; +30 điểm/30 ngày	Thấp – phụ thuộc chất lượng sổ đăng ký ban đầu
R3 Lộ mật khẩu/OTP	TOTP chống phát lại; khoá tạm; challenge thiết bị; thêm thiết bị cần admin	Thấp
R4 Đánh cắp phiên	Phê duyệt cần chữ ký thiết bị; phiên 15 phút; HttpOnly/SameSite	Thấp – kẻ gian chỉ xem được dữ liệu
R5 Mã độc tráo nội dung	Ký trên điện thoại (kênh thứ hai); chữ ký phủ toàn bộ nội dung	Trung bình nếu cả điện thoại cũng nhiễm mã độc
R6 Nội gián sửa CSDL	HMAC với khoá trong HSM; kiểm tra lại chữ ký khi thực thi	Thấp
R7 Tự duyệt / thông đồng	Tách biệt nhiệm vụ; 2 người với lệnh ≥ 50tr; bắt buộc GĐ với lệnh lớn	Trung bình – thông đồng nhiều người
R8 Mất điện thoại người duyệt	Khoá màn hình/sinh trắc; người thứ hai; khoá khẩn cấp huỷ chữ ký	Thấp với lệnh lớn; trung bình với lệnh < 50tr
R9 Phát lại chữ ký/OTP	Nonce, request_id, quyết định trong payload; danh sách chữ ký đã dùng; bộ đếm TOTP	Rất thấp
R10 Sửa/xoá nhật ký	Hash chain + HMAC + mốc neo ngoài	Thấp

CHƯƠNG 5. HỆ THỐNG DỰA VÀO ĐÂU ĐỂ TIN, KIỂM CHỨNG HOẶC TỪ CHỐI THÔNG TIN

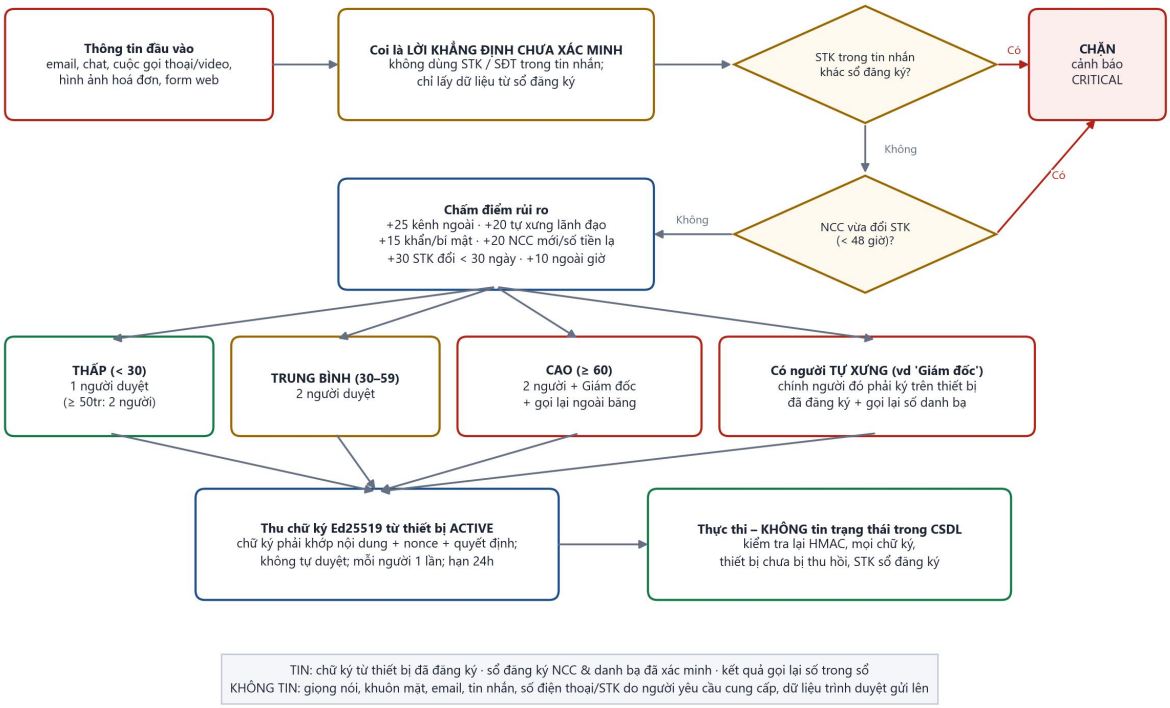
Đây là câu hỏi trọng tâm của đồ án: "Không phải mọi thông tin mà hệ thống nhận được đều đáng tin cậy." SafePay Guard trả lời bằng cách phân loại rõ ràng từng nguồn thông tin theo mức tin cậy, và chỉ cho phép tiền rời tài khoản khi quyết định dựa hoàn toàn trên các nguồn tin cậy.

5.1. Phân loại nguồn thông tin

Bảng 5.1. Mức tin cậy của từng nguồn thông tin

Nguồn thông tin	Mức tin cậy	Hệ thống xử lý thế nào
Chữ ký Ed25519 từ thiết bị ACTIVE, khớp nội dung + nonce	**TIN**	Bằng chứng duy nhất cho việc một người đã đồng ý
Sổ đăng ký NCC, danh bạ nội bộ (lập khi ký hợp đồng/nhận việc)	**TIN (mỏ neo)**	Nguồn của STK thụ hưởng và SĐT gọi lại
Kết quả gọi lại tới số trong sổ/danh bạ	TIN có điều kiện	Được ghi nhận kèm người gọi; người lập lệnh không được tự ghi
Dữ liệu lệnh trong CSDL	Kiểm chứng	Kiểm tra lại HMAC + chữ ký trước khi thực thi
Dữ liệu trình duyệt gửi lên	Kiểm chứng	Kiểm tra kiểu, phạm vi; STK luôn lấy từ sổ
Email, tin nhắn, văn bản scan, hoá đơn ảnh	KHÔNG TIN	Chỉ là lời khẳng định + nhãn kênh nguồn; tăng điểm rủi ro
Giọng nói, khuôn mặt trong cuộc gọi thoại/video	KHÔNG TIN	Như trên – không bao giờ đủ để phê duyệt
STK / SĐT do người yêu cầu cung cấp	KHÔNG TIN	STK khác sổ → chặn; SĐT gọi lại khác danh bạ → từ chối
Lời tự xưng "tôi là Giám đốc"	KHÔNG TIN	Chính người đó phải ký trên thiết bị của mình

5.2. Quy trình ra quyết định



Hình 5.1. Quy trình tin – kiểm chứng – từ chối một yêu cầu chuyển tiền

5.3. Tình huống 1 – Cuộc gọi video deepfake của Giám đốc

Kế toán Nguyễn Thị Lan nhận cuộc gọi video từ "Giám đốc Lê Hoàng Nam": hình ảnh, giọng nói giống thật, yêu cầu chuyển gấp 850 triệu đặt cọc một dự án "cần giữ bí mật" vào STK 9704 2299 8811.

Bảng 5.2. Diễn biến tình huống deepfake

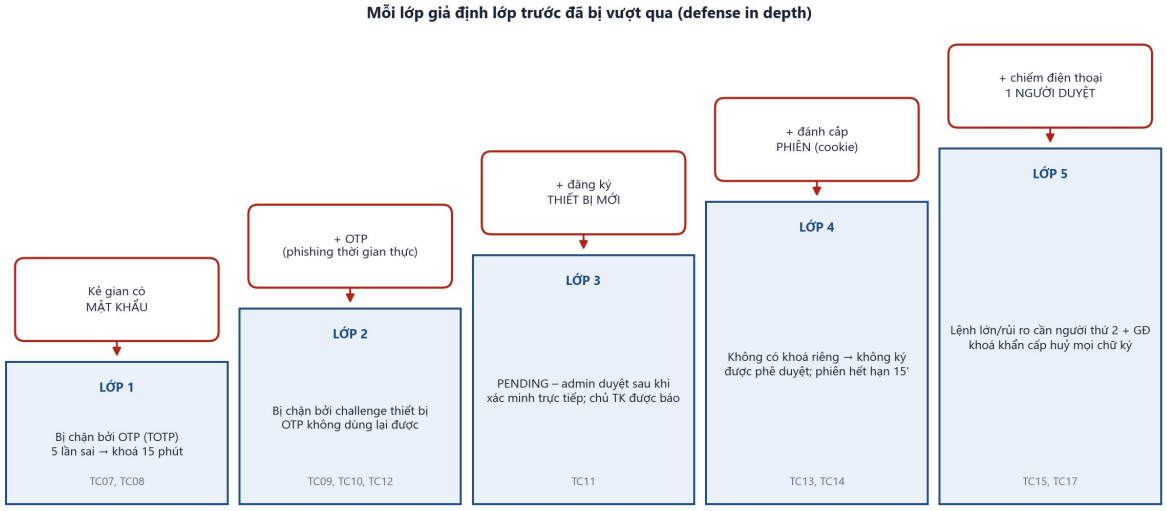
Bước	Hệ thống phản ứng
Kế toán nhập lệnh, ghi kênh "Cuộc gọi video", người tự xưng "Giám đốc", STK trong tin nhắn	STK trong tin nhắn khác sổ đăng ký → lệnh BLOCKED ngay, cảnh báo CRITICAL (KB03, TC16)
Biến thể: kẻ gian yêu cầu chuyển 300 triệu cho NCC có sẵn trong sổ	Rủi ro CAO (80–90 điểm); điều kiện: 2 người + chính GĐ Nam ký + gọi lại (KB04, TC17)
Kế toán trưởng và Phó GĐ đều duyệt	Vẫn chưa đủ – thiếu chữ ký của chính GĐ Nam và kết quả gọi lại
GĐ Nam nhận thông báo trên điện thoại	"Có lệnh … ghi là do bạn yêu cầu… Nếu không phải bạn, hãy TỪ CHỐI"
Người duyệt gọi lại số do "Giám đốc" đọc trong cuộc gọi	Từ chối SO_GOI_LAI_KHONG_HOP_LE (TC18)
Gọi số của GĐ trong danh bạ, GĐ phủ nhận	Lệnh REJECTED, cảnh báo nghi deepfake (TC19)

Điểm mấu chốt: hệ thống không cần biết cuộc gọi có phải deepfake hay không. Kể cả khi đó là Giám đốc thật, quy trình vẫn chỉ tốn thêm một lần bấm ký trên điện thoại của Giám đốc.

5.4. Tình huống 2 – Email giả nhà cung cấp đổi số tài khoản (BEC)

Email từ tên miền gần giống (minhphat-packaging.co) thông báo Công ty Bao Bì Minh Phát đổi sang tài khoản ACB 88886666999 "do kiểm toán", kèm số điện thoại liên hệ 0912 345 678. Hệ thống xử lý: yêu cầu đổi STK ở trạng thái PENDING_CALLBACK, STK cũ giữ nguyên; gọi số trong email bị từ chối; gọi số 028 3812 3456 trong sổ đăng ký – NCC xác nhận không gửi email; yêu cầu REJECTED, cảnh báo CRITICAL; mọi nỗ lực duyệt tiếp đều bị từ chối (KB05, TC20). Trường hợp NCC thật sự đổi tài khoản, quy trình vẫn thông qua nhưng kèm 48 giờ chờ (KB06, TC05, TC21).

5.5. Tình huống 3 – Tài khoản bị chiếm quyền



Hình 5.2. Các lớp phòng thủ khi tài khoản bị chiếm quyền

Bảng 5.3. Xử lý khi tài khoản bị chiếm quyền

Kẻ gian đã có…	Hệ thống xử lý	Test
Mật khẩu	Không có OTP → sai 5 lần thì khoá 15 phút, chủ TK được báo	TC07, TC08
Mật khẩu + OTP (trang giả mạo thời gian thực)	OTP đã dùng bị từ chối; đăng nhập từ thiết bị lạ bị từ chối + cảnh báo "mật khẩu và OTP có thể đã lộ"	TC09, TC10
Mật khẩu + OTP + biết mã thiết bị	Không có khoá riêng → chữ ký challenge sai	TC12
… và đăng ký "thiết bị mới"	PENDING tới khi admin xác minh trực tiếp; chủ TK được báo	TC11
Cookie phiên của người duyệt	Không ký được phê duyệt; phiên hết hạn sau 15 phút	TC13, TC14
Điện thoại đã mở khoá của 1 người duyệt	Lệnh ≥ 50tr/rủi ro cần người thứ 2; lệnh ≥ 500tr cần GĐ; khoá khẩn cấp thu hồi thiết bị, phiên và huỷ chữ ký đã ký	TC15, TC17

5.6. Tình huống 4 – Dữ liệu bị chỉnh sửa

- **Mã độc trên trình duyệt tráo số tiền hiển thị:** chữ ký không khớp nội dung lệnh → từ chối, cảnh báo (KB10, TC23).
- **Nội gián sửa STK/số tiền trực tiếp trong CSDL sau khi duyệt:** HMAC không khớp → BLOCKED khi thực thi (KB11, TC24).
- **Dùng lại chữ ký cũ / dùng chữ ký từ chối làm phê duyệt:** từ chối (TC25, TC26) – phân tích ở mục 5.8.
- **Sửa, xoá bản ghi giữa hoặc cắt cụt nhật ký:** phát hiện bằng hash chain, HMAC và mốc neo (KB14, TC27).

5.7. Tình huống 5 – Hình ảnh giả mạo (ảnh hoá đơn, ảnh chụp màn hình)

Hình ảnh là loại "chứng từ" dễ làm giả nhất: chỉ cần một phần mềm chỉnh ảnh để sửa số tài khoản trên ảnh chụp hoá đơn, hoặc ghép một ảnh chụp màn hình tin nhắn "Giám đốc đã duyệt, chuyển luôn". Hệ thống có kênh nguồn riêng "Hình ảnh" và xử lý nó như mọi kênh bên ngoài: nội dung trên ảnh chỉ là lời khẳng định để đối chiếu với mỏ neo tin cậy.

Bảng 5.4. Diễn biến tình huống hình ảnh giả mạo

Bước	Hệ thống phản ứng
Kế toán nhận qua Zalo ảnh hoá đơn HĐ 0001240 của Bao Bì Minh Phát; STK trên ảnh đã bị sửa thành 0071000999888	Lệnh luôn lấy STK từ sổ đăng ký (0071000123456). STK trên ảnh được nhập vào ô đối chiếu, khác sổ → lệnh BLOCKED, cảnh báo CRITICAL (KB15, TC33)
Kẻ gian gửi tiếp ảnh chụp màn hình "Giám đốc đã duyệt, chuyển luôn" để hối thúc	Ảnh không phải chữ ký. Lệnh được ghi kênh "Hình ảnh", tự xưng Giám đốc → +45 điểm (MEDIUM): cần 2 người duyệt, chính GĐ Nam ký trên thiết bị và gọi lại xác minh
Kế toán trưởng duyệt, kế toán bấm thực thi vì tin vào ảnh	Từ chối CHUA_DU_PHE_DUYET – thiếu chữ ký của chính Giám đốc và kết quả gọi lại (KB15, TC33)

Hệ thống không cố phân tích ảnh có bị chỉnh sửa hay không (pháp y ảnh tốn kém và dễ bị qua mặt khi ảnh được nén lại hoặc chụp lại màn hình). Thay vào đó, không thông tin nào trên ảnh được dùng trực tiếp: STK lấy từ sổ đăng ký, còn "sự đồng ý" chỉ được chứng minh bằng chữ ký số của chính người có thẩm quyền.

5.8. Đầu vào thật nhưng bị sử dụng sai ngữ cảnh

Đây là dạng khó nhận ra nhất: dữ liệu hoàn toàn thật và hợp lệ – một chữ ký đúng, một mã OTP đúng, một phiên đăng nhập hợp lệ, một số điện thoại có thật – nhưng bị đem dùng ở chỗ khác, lúc khác hoặc cho mục đích khác với lúc nó được tạo ra. Nếu hệ thống chỉ hỏi "chữ ký này có hợp lệ không?" thì câu trả lời là có. SafePay Guard hỏi

thêm "chữ ký này được tạo ra cho việc gì?" bằng cách ràng buộc mỗi bằng chứng với đúng ngữ cảnh của nó (context binding).

Bảng 5.5. Chống sử dụng sai ngữ cảnh bằng ràng buộc ngữ cảnh

Dữ liệu thật	Bị dùng sai ngữ cảnh thế nào	Ràng buộc ngữ cảnh	Kết quả	Test
Chữ ký phê duyệt lệnh A	Gửi lên làm phê duyệt cho lệnh B cùng số tiền, cùng NCC	request_id và nonce riêng của từng lệnh nằm trong nội dung ký	CHU_KY_KHONG_HOP_LE	TC25
Chữ ký đã được dùng	Gửi lại lần thứ hai	Danh sách chữ ký đã dùng	CHU_KY_DA_SU_DUNG	TC25
Chữ ký TỪ CHỐI	Gửi lên như PHÊ DUYỆT	Trường decision nằm trong nội dung ký	CHU_KY_KHONG_HOP_LE	TC26
Mã OTP đúng	Trang giả mạo dùng lại mã vừa bắt được	Bộ đếm TOTP cuối cùng của từng người	OTP_DA_SU_DUNG	TC09
Cookie phiên hợp lệ	Dùng để phê duyệt thay vì chỉ để xem	Phê duyệt cần chữ ký của thiết bị, không chỉ phiên	CHU_KY_KHONG_HOP_LE	TC13
Lệnh đã được duyệt	Phê duyệt cũ dùng để chuyển sau khi STK NCC đã đổi	Khi thực thi, STK của lệnh phải khớp sổ hiện tại	TAI_KHOAN_THAY_DOI	TC22
Yêu cầu chờ duyệt	Được duyệt sau hơn 24 giờ	expires_at nằm trong nội dung ký, lệnh hết hạn sau 24 giờ	YEU_CAU_HET_HAN	TC30
Phê duyệt từ thiết bị trước khi bị báo mất	Dùng để thực thi sau khi thiết bị bị chiếm	Khoá khẩn cấp huỷ mọi phê duyệt chưa thực thi	Lệnh không thực thi được	TC15
Số điện thoại có thật (của kẻ gian)	Dùng làm kênh gọi lại xác minh	Chỉ chấp nhận số trong danh bạ/sổ đăng ký	SO_GOI_LAI_KHONG_HOP_LE	TC18

5.9. Tổng hợp theo bốn dạng đầu vào không đáng tin

Bảng 5.6. Bốn dạng đầu vào không đáng tin và cách hệ thống xử lý

Dạng đầu vào (theo đề)	Ví dụ trong hệ thống	Mục	Kịch bản / test
Giả mạo	Cuộc gọi video/thoại deepfake, email giả NCC, ảnh hoá đơn bị sửa, ảnh chụp màn hình "đã duyệt", lời tự xưng lãnh đạo	5.3, 5.4, 5.7	KB03–KB05, KB15; TC16–TC21, TC33
Chỉnh sửa	Tráo số tiền trên màn hình ký, sửa CSDL sau khi duyệt, sửa/xoá nhật ký	5.6	KB10, KB11, KB14; TC23, TC24, TC27
Đánh cắp	Mật khẩu, OTP, cookie phiên, điện thoại của người duyệt	5.5	KB07–KB09, KB13; TC07–TC15
Sử dụng sai ngữ cảnh	Chữ ký của lệnh khác, chữ ký từ chối, OTP cũ, phê duyệt quá hạn, số gọi lại của kẻ gian	5.8	TC09, TC13, TC15, TC18, TC22, TC25, TC26, TC30

CHƯƠNG 6. PROTOTYPE

6.1. Công nghệ sử dụng

Bảng 6.1. Công nghệ

Thành phần	Công nghệ
Ngôn ngữ, web	Python 3.12+ (đã chạy trên 3.14), Flask 3
Chữ ký số	Ed25519 – thư viện cryptography (pyca)
Băm mật khẩu	Argon2id – argon2-cffi
TOTP, HMAC, hash chain	Thư viện chuẩn hmac, hashlib (cài đặt RFC 6238)
Kiểm thử	pytest; đồng hồ giả lập (FakeClock) để kiểm thử hết hạn, khoá tạm, thời gian chờ
Sơ đồ	matplotlib (so_do/ve_so_do.py)

6.2. Cấu trúc mã nguồn

Bảng 6.2. Cấu trúc mã nguồn

Tệp	Nội dung
prototype/safepay/crypto.py	Argon2id, TOTP, JSON chuẩn hoá, HMAC, khoá/chữ ký Ed25519
prototype/safepay/core.py	Lõi nghiệp vụ & chính sách: người dùng, thiết bị, đăng nhập, sổ đăng ký, đổi STK, lệnh, phê duyệt, gọi lại, thực thi, khoá khẩn cấp
prototype/safepay/risk.py	Bộ chấm điểm rủi ro theo luật
prototype/safepay/audit.py	Nhật ký chuỗi băm + HMAC + mốc neo
prototype/safepay/device.py	Mô phỏng ứng dụng ký trên điện thoại (giữ khoá riêng)
prototype/safepay/seed.py	Dữ liệu mẫu: 5 người dùng, 3 nhà cung cấp, đồng hồ giả lập
prototype/safepay/scenarios.py	15 kịch bản demo (bình thường + tấn công)
prototype/app.py, templates/	Giao diện web demo
prototype/demo_cli.py	Chạy toàn bộ kịch bản trên terminal
prototype/tests/test_safepay.py	33 test case (38 lượt chạy)

6.3. Cài đặt và chạy

```
pip install flask cryptography argon2-cffi pytest
cd prototype
python demo_cli.py          # chạy 15 kịch bản trên terminal
python -m pytest -v         # chạy bộ kiểm thử
python app.py               # giao diện web: http://127.0.0.1:5000
```

Trên trang đăng nhập có bảng tài khoản demo và mã OTP hiện tại của từng người (mô phỏng ứng dụng Authenticator). Mỗi người dùng có một thiết bị hợp lệ "<tên đăng nhập>-phone". Giao diện có sẵn các nút mô phỏng tấn công: tráo nội dung khi ký, sửa trực tiếp CSDL, sửa/xoá nhật ký, và trang "Kịch bản tấn công" chạy toàn bộ 15 kịch bản.

Bảng 6.3. Tài khoản demo

Tài khoản	Vai trò	Mật khẩu demo	SĐT trong danh bạ
ketoan	Kế toán viên	KeToan@2026	0901 000 001
ketoantruong	Kế toán trưởng	KTT#Minh2026	0901 000 002
giamdoc	Giám đốc	GD!Nam2026	0901 000 003
phogiamdoc	Phó Giám đốc	PGD@Ha2026	0901 000 004
admin	Quản trị hệ thống	Admin#Bao2026	0901 000 005

6.4. Kịch bản demo đề xuất khi thuyết trình

- KB01 – Lệnh 40 triệu: kế toán tạo, kế toán trưởng ký trên "điện thoại", thực thi (luồng bình thường, ~1 phút).
- KB04 – Giả giọng Giám đốc: tạo lệnh từ "Cuộc gọi thoại", tự xưng Giám đốc → xem điều kiện còn thiếu → thử gọi lại số kẻ gian → bị từ chối.
- KB05 – Email giả NCC: tiếp nhận đổi STK → gọi số trong email bị từ chối → NCC phủ nhận.
- KB10 – Bấm "Tấn công: mã độc tráo số tiền" trên màn hình lệnh → chữ ký bị từ chối.
- KB11 – Bấm "Sửa trực tiếp trong CSDL" trên lệnh đã duyệt → thực thi bị chặn.
- KB14 – Trang Nhật ký: gửi mốc neo → sửa 1 bản ghi / xoá 2 bản ghi → hệ thống báo phát hiện.
- KB15 – Tạo lệnh với kênh "Hình ảnh" và STK đọc từ ảnh hoá đơn bị sửa → lệnh bị chặn.

6.5. Giới hạn của prototype

- Dữ liệu lưu trong bộ nhớ; bản triển khai thật cần CSDL (PostgreSQL) và khoá HMAC trong HSM/KMS.
- Ứng dụng điện thoại được mô phỏng bằng lớp DeviceWallet chạy cùng máy chủ; bản thật dùng ứng dụng di động lưu khoá trong Secure Enclave/StrongBox hoặc khoá FIDO2/passkey.
- Chưa tích hợp API ngân hàng (mã giao dịch được giả lập), chưa có HTTPS và chống CSRF token (đã dùng SameSite=Strict).
- Kết quả gọi lại do người duyệt tự khai; bản thật có thể dùng tổng đài ghi âm hoặc xác nhận bằng chữ ký từ ứng dụng của chính người được gọi.

CHƯƠNG 7. KIỂM THỬ

7.1. Phương pháp

Bộ kiểm thử tự động viết bằng pytest, mỗi test chạy trên một môi trường dữ liệu mới. Đồng hồ giả lập cho phép kiểm tra các tình huống phụ thuộc thời gian (OTP, khoá tạm 15 phút, phiên 15 phút, lệnh hết hạn 24 giờ, thời gian chờ 48 giờ) mà không phải chờ thật. Mỗi test kiểm tra cả mã lỗi chính sách trả về, không chỉ việc có lỗi xảy ra. Test case chia thành 5 nhóm: luồng bình thường, chiếm tài khoản, đầu vào giả mạo, sửa đổi dữ liệu, phân quyền/kiểm tra đầu vào.

7.2. Bộ test case và kết quả

Bảng 7.1. Bộ test case và kết quả kiểm thử

Mã	Nhóm	Tình huống	Kết quả mong đợi	Kết quả
TC01	Bình thường	Đăng nhập đúng mật khẩu + OTP từ thiết bị đã đăng ký	Đăng nhập thành công, tạo phiên gắn với thiết bị	ĐẠT
TC02	Bình thường	Lệnh 40 triệu cho nhà cung cấp quen, tạo trên hệ thống	Rủi ro LOW, 1 người duyệt, thực thi thành công	ĐẠT
TC03	Bình thường	Lệnh 120 triệu	Cần 2 người duyệt; 1 người duyệt chưa thực thi được; đủ 2 người thì thực thi	ĐẠT
TC04	Bình thường	Lệnh 600 triệu (≥ 500 triệu)	Bắt buộc có chữ ký Giám đốc/Phó GĐ	ĐẠT
TC05	Bình thường	NCC đổi STK thật: gọi lại đúng số trong sổ, Kế toán trưởng ký duyệt, chờ 48h	STK được cập nhật; sau 48h thanh toán được (rủi ro MEDIUM, 2 người duyệt)	ĐẠT
TC06	Bình thường	Người duyệt ký TỪ CHỐI	Lệnh chuyển REJECTED, không thể thực thi	ĐẠT
TC07	Chiếm tài khoản	Sai mật khẩu	Từ chối với thông báo chung (không lộ tài khoản có tồn tại hay không)	ĐẠT
TC08	Chiếm tài khoản	Lộ mật khẩu, kẻ gian đoán OTP 5 lần	Tài khoản bị khoá 15 phút, chủ tài khoản được cảnh báo; hết 15 phút đăng nhập lại được	ĐẠT
TC09	Chiếm tài khoản	Sử dụng sai ngữ cảnh – phát lại mã OTP vừa được dùng (bắt được qua trang giả mạo)	Từ chối OTP_DA_SU_DUNG	ĐẠT
TC10	Chiếm tài khoản	Kẻ gian có mật khẩu + OTP thật, đăng nhập từ máy của mình	Từ chối THIET_BI_CHUA_DANG_KY, cảnh báo chủ tài khoản	ĐẠT
TC11	Chiếm tài khoản	Kẻ gian đăng ký 'thiết bị mới' bằng mật khẩu + OTP lộ	Thiết bị ở trạng thái PENDING, không đăng nhập được; admin không được tự duyệt thiết bị của mình	ĐẠT
TC12	Chiếm tài khoản	Kẻ gian khai báo đúng mã thiết bị 'ketoan-phone' nhưng không có khoá riêng	Từ chối CHU_KY_KHONG_HOP_LE	ĐẠT
TC13	Chiếm tài khoản	Kẻ gian đánh cắp cookie phiên của Kế toán trưởng và gửi phê duyệt	Từ chối vì không có khoá riêng trên điện thoại người duyệt	ĐẠT
TC14	Chiếm tài khoản	Dùng lại phiên bỏ quên sau 16 phút không hoạt động	Phiên hết hạn PHIEN_HET_HAN	ĐẠT
TC15	Chiếm tài khoản	Thiết bị Kế toán trưởng bị chiếm đã ký duyệt 1 lệnh; admin kích hoạt khoá khẩn cấp	Thu hồi thiết bị + phiên, phê duyệt bị huỷ, lệnh không thực thi được	ĐẠT
TC16	Đầu vào giả	Cuộc gọi video deepfake 'Giám đốc'	Lệnh bị CHẶN ngay (STK trong tin	ĐẠT

Mã	Nhóm	Tình huống	Kết quả mong đợi	Kết quả
	mạo	yêu cầu chuyển gấp 850 triệu vào STK lạ	nhắn khác sổ đăng ký), cảnh báo CRITICAL	
TC17	Đầu vào giả mạo	Giả giọng Giám đốc yêu cầu chuyển 300 triệu cho NCC có sẵn	Rủi ro HIGH; KTT + Phó GĐ duyệt vẫn chưa đủ – phải có chính Giám đốc ký trên thiết bị và gọi lại xác minh	ĐẠT
TC18	Đầu vào giả mạo	Người duyệt gọi lại số điện thoại do kẻ gian đọc trong cuộc gọi	Từ chối SO_GOI_LAI_KHONG_HOP_LE – chỉ chấp nhận số trong danh bạ nội bộ	ĐẠT
TC19	Đầu vào giả mạo	Gọi lại số thật của Giám đốc, GĐ xác nhận không hề yêu cầu	Lệnh REJECTED, cảnh báo nghi deepfake	ĐẠT
TC20	Đầu vào giả mạo	Email giả NCC yêu cầu đổi STK, kèm số điện thoại 'liên hệ'	STK không đổi; gọi số trong email bị từ chối; NCC phủ nhận → yêu cầu REJECTED, không thể duyệt	ĐẠT
TC21	Đầu vào giả mạo	Tạo lệnh trong 48 giờ ngay sau khi STK NCC được đổi	Lệnh bị CHẶN (thời gian chờ an toàn)	ĐẠT
TC22	Đầu vào giả mạo	Lệnh đã duyệt nhưng STK NCC bị đổi trước khi thực thi	Từ chối TAI_KHOAN_THAY_DOI, lệnh BLOCKED	ĐẠT
TC23	Sửa đổi dữ liệu	Mã độc tráo số tiền hiển thị trên màn hình ký (48 triệu → 4,8 triệu)	Chữ ký không khớp nội dung lệnh → từ chối, cảnh báo	ĐẠT
TC24	Sửa đổi dữ liệu	Nội gián sửa số tiền/STK trực tiếp trong CSDL sau khi lệnh được duyệt	Thực thi bị từ chối DU_LIEU_BI_SUA_DOI (HMAC toàn vẹn + chữ ký không khớp)	ĐẠT
TC25	Sửa đổi dữ liệu	Sử dụng sai ngữ cảnh – dùng chữ ký của lệnh A cho lệnh B; dùng lại chữ ký đã dùng	Từ chối (CHU_KY_KHONG_HOP_LE / CHU_KY_DA_SU_DUNG)	ĐẠT
TC26	Sửa đổi dữ liệu	Sử dụng sai ngữ cảnh – lấy chữ ký TỪ CHỐI của người duyệt rồi gửi lên như PHÊ DUYỆT	Từ chối vì quyết định nằm trong nội dung được ký	ĐẠT
TC27	Sửa đổi dữ liệu	Sửa nội dung, xoá bản ghi giữa, cắt bỏ bản ghi cuối của nhật ký kiểm toán	Cả 3 trường hợp đều bị phát hiện (chuỗi băm + HMAC + mốc neo)	ĐẠT
TC28	Phân quyền	Kế toán trưởng tự tạo lệnh rồi tự duyệt	Từ chối TACH_BIET_NHIEM_VU	ĐẠT
TC29	Phân quyền	Kế toán viên cố phê duyệt lệnh của người khác; admin cố tạo lệnh	Từ chối KHONG_CO_QUYEN	ĐẠT
TC30	Phân quyền	Phê duyệt lệnh đã quá 24 giờ	Từ chối YEU_CAU_HET_HAN, lệnh EXPIRED	ĐẠT
TC31	Phân quyền	Số tiền không hợp lệ (0, âm, vượt hạn mức 10 tỷ, sai kiểu dữ liệu: chuỗi, số thực, True)	Từ chối DU_LIEU_KHONG_HOP_LE	ĐẠT (6/6)
TC32	Phân quyền	Một người duyệt 2 lần để đủ số lượng; người tạo lệnh tự ghi nhận gọi lại	Từ chối DA_PHE_DUYET / KHONG_CO_QUYEN	ĐẠT
TC33	Đầu vào giả mạo	Ảnh hoá đơn NCC bị sửa STK gửi qua Zalo; ảnh chụp màn hình 'Giám đốc đã duyệt'	Lệnh theo ảnh hoá đơn bị CHẶN (STK khác sổ đăng ký); ảnh chụp màn hình không được tính là phê duyệt – thiếu chữ ký của chính Giám đốc nên không thực thi được	ĐẠT

7.3. Tổng hợp kết quả

Bảng 7.2. Tổng hợp kết quả kiểm thử

Chỉ số	Giá trị
Số test case	33 (TC31 chạy 6 bộ dữ liệu)
Số lượt chạy	38
Đạt	38/38 (100%)
Tình huống bình thường	6 test case

Chỉ số	Giá trị
Tình huống rủi ro/tấn công	27 test case
Thời gian chạy	≈ 10 giây (chủ yếu do Argon2id cố ý chậm)

Kết quả chi tiết lưu trong thư mục ket_qua_kiem_thu/ (pytest_output.txt, junit.xml, demo_kich_ban.txt). Lưu ý: kiểm thử chứng minh hệ thống thực hiện đúng chính sách đã thiết kế trong các tình huống đã nêu; nó không chứng minh hệ thống an toàn trước mọi tấn công – đặc biệt các rủi ro còn lại ở Bảng 4.4.

7.4. Truy vết rủi ro – test case

Bảng 7.3. Ma trận truy vết

Rủi ro	Test case kiểm chứng
R1 Giả danh lãnh đạo	TC16, TC17, TC18, TC19, TC33
R2 Email/hoá đơn giả NCC (BEC)	TC05, TC20, TC21, TC22, TC33
R3 Lộ mật khẩu/OTP	TC07, TC08, TC09, TC10, TC11, TC12
R4 Đánh cắp phiên	TC13, TC14
R5 Mã độc tráo nội dung	TC23
R6 Nội gián sửa CSDL	TC24
R7 Tự duyệt / vượt quyền	TC28, TC29, TC32
R8 Mất điện thoại người duyệt	TC15
R9 Phát lại	TC09, TC25, TC26
R10 Sửa nhật ký	TC27
Luồng nghiệp vụ bình thường	TC01–TC06, TC30, TC31

CHƯƠNG 8. PHÂN TÍCH TRADE-OFF

Không có thiết kế an toàn nào miễn phí. Chương này phân tích các đánh đổi chính, xét cả ngắn hạn (3–6 tháng đầu triển khai) và dài hạn (từ năm thứ hai).

8.1. An toàn và tiện lợi: phê duyệt nhiều lớp, gọi lại, thời gian chờ

- **Ngắn hạn – chi phí:** mỗi lệnh ≥ 50 triệu cần hai người, lệnh rủi ro cao cần thêm cuộc gọi và Giám đốc; NCC đổi tài khoản phải chờ 48 giờ. Những khoản thanh toán thật sự gấp (hàng nhập khẩu, hạn chót hợp đồng) có thể bị chậm, nhân viên và lãnh đạo dễ phản ứng, thậm chí tìm cách "đi đường vòng" (chuyển tiền thẳng trên Internet Banking).
- **Ngắn hạn – giảm thiểu:** duyệt trên điện thoại chỉ mất vài giây; ngưỡng 50 triệu được chọn sao cho phần lớn giao dịch thường ngày (dữ liệu mẫu: 12–45 triệu) chỉ cần 1 người; các yêu cầu bổ sung chỉ kích hoạt khi có tín hiệu rủi ro; ngân hàng được cấu hình để lệnh chỉ được gửi qua hệ thống (khoá đường vòng).
- **Dài hạn:** quy trình trở thành thói quen; nhân viên có "lý do chính đáng" để từ chối yêu cầu gấp của "sếp" (vì hệ thống bắt buộc), giảm áp lực tâm lý – chính là điểm yếu mà kẻ lừa đảo khai thác. Lịch sử thanh toán dày lên giúp chấm điểm chính xác hơn, ít báo động nhầm hơn. Chỉ cần ngăn được một vụ BEC (thường hàng trăm triệu đến hàng tỷ đồng) là đã bù đắp chi phí chậm trễ nhiều năm.

8.2. An toàn và chi phí

Bảng 8.1. Đánh đổi an toàn – chi phí

Phương án	Chi phí ngắn hạn	Lợi ích / chi phí dài hạn
Khoá trong ứng dụng điện thoại (đề xuất)	Thấp – dùng điện thoại sẵn có; chi phí phát triển ứng dụng	Phụ thuộc an toàn điện thoại cá nhân; cần quy trình khi đổi/mất máy
Khoá bảo mật phần cứng FIDO2 cho người duyệt	~0,5–1,5 triệu đ/khoá × số người duyệt	An toàn hơn trước mã độc điện thoại; nhưng màn hình hiển thị giao dịch hạn chế
HSM/KMS cho khoá HMAC	Dịch vụ KMS đám mây chi phí thấp; HSM vật lý đắt	Cần thiết để chống nội gián có quyền CSDL
Bổ sung phát hiện deepfake bằng AI	Chi phí bản quyền/tích hợp cao	Cuộc đua vũ trang: mô hình phát hiện lỗi thời nhanh; tỷ lệ bỏ sót không thể bằng 0 → không dùng làm cơ chế quyết định

Lựa chọn của đồ án: ưu tiên các biện pháp có chi phí thấp nhưng thay đổi bản chất của bài toán (chữ ký, sổ đăng ký, gọi lại), thay vì đầu tư vào phát hiện deepfake – vốn chỉ giảm xác suất, không loại bỏ được rủi ro, và sẽ ngày càng kém hiệu quả.

8.3. An toàn và riêng tư

Nhật ký chi tiết và chấm điểm rủi ro cần thu thập dữ liệu về hành vi người dùng (thời gian đăng nhập, thiết bị, lịch sử thanh toán, số điện thoại). Ngắn hạn, điều này giúp điều tra sự cố dễ dàng; dài hạn, kho dữ liệu này trở thành mục tiêu hấp dẫn và có thể bị dùng sai mục đích (giám sát nhân viên). Thiết kế giới hạn: chỉ thu thập dữ liệu phục vụ trực tiếp quyết định bảo mật (không thu vị trí GPS, không ghi âm cuộc gọi trong prototype), không lưu nội dung email gốc mà chỉ lưu tóm tắt do kế toán nhập, và cần chính sách lưu trữ có thời hạn phù hợp quy định pháp luật về kế toán và bảo vệ dữ liệu cá nhân.

8.4. Khả năng triển khai

- **Ngắn hạn:** nhiều ngân hàng chưa cung cấp API cho doanh nghiệp nhỏ. Hệ thống có thể chạy như lớp phê duyệt độc lập: kế toán nhập lệnh đã duyệt lên Internet Banking thủ công kèm mã lệnh. Cách này triển khai nhanh nhưng còn khe hở – kế toán có thể nhập sai/nhập khác. Giảm thiểu bằng đối soát hằng ngày sao kê ngân hàng với nhật ký hệ thống, và dùng tính năng "người duyệt thứ hai" sẵn có của Internet Banking.
- **Dài hạn:** khi ngân hàng mở API (xu hướng Open API ngân hàng), lệnh được gửi trực tiếp từ bộ thực thi kèm chữ ký, loại bỏ bước nhập tay; tài khoản Internet Banking của kế toán chỉ còn quyền xem.

8.5. Tổng hợp

Bảng 8.2. Tổng hợp các trade-off

Đánh đổi	Ngắn hạn	Dài hạn	Quyết định
Phê duyệt nhiều lớp vs tốc độ	Chậm, phản ứng của người dùng	Thành thói quen, giảm áp lực tâm lý	Áp dụng theo rủi ro, không áp dụng đồng loạt
48h chờ khi đổi STK vs thanh toán đúng hạn	Có thể trễ hạn hợp đồng	Chặn gần như toàn bộ BEC đổi tài khoản	Giữ 48h; NCC được thông báo quy trình từ khi ký hợp đồng
Chữ ký thiết bị vs chi phí	Phát triển ứng dụng, đào tạo	Chi phí vận hành thấp, an toàn bền vững	Ứng dụng điện thoại; FIDO2 cho GĐ nếu có ngân sách
Luật minh bạch vs AI phát hiện	Luật dễ làm, có thể báo động nhầm	AI mạnh hơn nhưng khó giải thích	Luật để quyết định; AI (nếu có) chỉ tăng điểm
Nhật ký đầy đủ vs riêng tư	Điều tra dễ	Rủi ro lộ/lạm dụng dữ liệu	Thu thập tối thiểu, có thời hạn lưu
Tích hợp ngân hàng	Lớp duyệt độc lập + đối soát	API trực tiếp	Triển khai theo 2 giai đoạn

CHƯƠNG 9. HẠN CHẾ, HƯỚNG PHÁT TRIỂN VÀ KẾT LUẬN

9.1. Hạn chế

- Toàn bộ thiết kế dựa vào chất lượng sổ đăng ký và danh bạ ban đầu; nếu dữ liệu gốc sai (nhập nhầm STK lúc ký hợp đồng) thì mọi kiểm tra sau đều dựa trên dữ liệu sai.
- Không chống được thông đồng của đủ số người duyệt cần thiết (ví dụ Kế toán trưởng + Giám đốc cùng gian lận).
- Lệnh dưới 50 triệu, rủi ro thấp chỉ cần một người duyệt – nếu điện thoại người đó bị chiếm hoàn toàn, có thể mất một khoản nhỏ trước khi khoá khẩn cấp.
- Kết quả gọi lại được ghi nhận bởi con người, có thể bị làm giả bởi người duyệt gian lận.
- Prototype chưa có HTTPS, CSDL bền vững, HSM, ứng dụng di động thật.

9.2. Hướng phát triển

- Ứng dụng di động thật dùng passkey/FIDO2 và Secure Enclave; xác nhận sinh trắc trước khi ký.
- Gọi lại tự động: hệ thống gửi yêu cầu xác nhận tới ứng dụng của chính người được nêu tên thay cho cuộc gọi thủ công.
- Xác minh hoá đơn điện tử với cơ quan thuế (mã số thuế, mã tra cứu) và đối chiếu MST – STK.
- Tích hợp tra cứu tên chủ tài khoản qua ngân hàng (account name inquiry) trước khi thêm/đổi STK.
- Mô hình học máy phát hiện bất thường bổ sung điểm rủi ro (chỉ được phép tăng điểm).
- Ghi mốc neo nhật ký lên dịch vụ lưu trữ bất biến (Object Lock) hoặc dịch vụ timestamp RFC 3161.

9.3. Kết luận

Đồ án đã thiết kế và hiện thực hoá SafePay Guard – hệ thống phê duyệt lệnh chuyển tiền giải quyết bài toán thực tế là lừa đảo giả danh lãnh đạo/nhà cung cấp, kể cả bằng deepfake. Thay vì cố phân biệt thật – giả của hình ảnh, giọng nói hay email, hệ thống chuyển gốc rễ của niềm tin sang những thứ kẻ gian không làm giả được với chi phí hợp lý: chữ ký số từ thiết bị đã đăng ký, dữ liệu gốc đã xác minh, và kênh xác minh độc lập. Các cơ chế được ánh xạ trực tiếp tới từng rủi ro, minh hoạ bằng prototype

chạy được, 15 kịch bản demo và 33 test case (38/38 lượt đạt), đồng thời các đánh đổi về tiện lợi, chi phí, riêng tư và khả năng triển khai đã được phân tích để hệ thống có thể áp dụng thực tế theo lộ trình.

TÀI LIỆU THAM KHẢO

[1] Federal Bureau of Investigation – Internet Crime Complaint Center (IC3), Internet Crime Report 2023, 2024.

[2] CNN, "Finance worker pays out $25 million after video call with deepfake 'chief financial officer'", 02/2024; Arup xác nhận vụ việc 05/2024.

[3] NIST SP 800-63B, Digital Identity Guidelines: Authentication and Lifecycle Management.

[4] NIST SP 800-53 Rev. 5, Security and Privacy Controls (AC-5 Separation of Duties, AU-9 Protection of Audit Information, IA-2 Identification and Authentication).

[5] D. M'Raihi et al., RFC 6238 – TOTP: Time-Based One-Time Password Algorithm, IETF, 2011.

[6] S. Josefsson, I. Liusvaara, RFC 8032 – Edwards-Curve Digital Signature Algorithm (EdDSA), IETF, 2017.

[7] A. Biryukov, D. Dinu, D. Khovratovich, S. Josefsson, RFC 9106 – Argon2 Memory-Hard Function, IETF, 2021.

[8] H. Krawczyk, M. Bellare, R. Canetti, RFC 2104 – HMAC: Keyed-Hashing for Message Authentication, IETF, 1997.

[9] B. Schneier, J. Kelsey, "Secure Audit Logs to Support Computer Forensics", ACM TISSEC, 1999.

[10] A. Shostack, Threat Modeling: Designing for Security, Wiley, 2014 (mô hình STRIDE).

[11] OWASP Application Security Verification Standard (ASVS) 4.0.3.

[12] J. H. Saltzer, M. D. Schroeder, "The Protection of Information in Computer Systems", Proc. IEEE, 1975 (các nguyên tắc thiết kế an toàn).

PHỤ LỤC. KẾT QUẢ CHẠY KỊCH BẢN DEMO

Trích từ ket_qua_kiem_thu/demo_kich_ban.txt (python demo_cli.py).

```
=== KB01 – Luồng bình thường: lệnh nhỏ, 1 người duyệt ===
  1. [THÀNH CÔNG] Kế toán tạo lệnh 40 triệu cho nhà cung cấp quen
       → Rủi ro LOW (0), cần 1 người duyệt
  2. [THÀNH CÔNG] Kế toán trưởng xem nội dung trên điện thoại và ký duyệt
       → Trạng thái: APPROVED
  3. [THÀNH CÔNG] Lệnh được gửi sang ngân hàng
       → Mã giao dịch FTDA92FD2925
=== KB02 – Luồng bình thường: lệnh 120 triệu, 2 người duyệt ===
  1. [THÀNH CÔNG] Tạo lệnh 120 triệu
       → Rủi ro LOW, cần 2 người duyệt
  2. [THÔNG TIN] Kế toán trưởng duyệt – chưa đủ
       → Cần 2 người duyệt, mới có 1
  3. [THÀNH CÔNG] Giám đốc duyệt → lệnh được thực thi
       → Mã giao dịch FT165ABD65A7
=== KB03 – Deepfake video Giám đốc + số tài khoản lạ ===
  1. [THÔNG TIN] Kế toán nhận cuộc gọi video 'Giám đốc Lê Hoàng Nam'
(deepfake): chuyển gấp 850 triệu đặt cọc dự án mật, STK 9704 2299 8811
       → Hình ảnh và giọng nói giống thật – hệ thống KHÔNG dựa vào đó
  2. [THÀNH CÔNG] Hệ thống chấm điểm rủi ro
       → Trạng thái BLOCKED: Số tài khoản trong tin nhắn (970422998811)
KHÁC số tài khoản đã xác minh trong sổ đăng ký (19033334444015) – dấu hiệu
lừa đảo đổi tài khoản (BEC)
=== KB04 – Giả giọng Giám đốc, chuyển cho NCC có sẵn ===
  1. [THÀNH CÔNG] Kẻ gian giả giọng Giám đốc, yêu cầu chuyển 300 triệu cho
NCC có trong sổ
       → Rủi ro HIGH (80 điểm). Điều kiện: Cần 2 người duyệt, mới có 0;
Cần chữ ký của Giám đốc / Phó Giám đốc; Cần chính Lê Hoàng Nam ký xác nhận
trên thiết bị đã đăng ký; Cần gọi lại xác minh qua số điện thoại trong
danh bạ/sổ đăng ký
  2. [BỊ CHẶN] Kế toán thử thực thi khi mới có Kế toán trưởng duyệt
       → CHUA_DU_PHE_DUYET: Lệnh chưa đủ điều kiện thực thi: Cần 2 người
duyệt, mới có 1; Cần chữ ký của Giám đốc / Phó Giám đốc; Cần chính Lê
Hoàng Nam ký xác nhận trên thiết bị đã đăng ký; Cần gọi lại xác minh qua
số điện thoại trong danh bạ/sổ đăng ký
  3. [BỊ CHẶN] Kế toán trưởng gọi lại số do 'Giám đốc' đọc trong cuộc gọi
(0988 777 666)
       → SO_GOI_LAI_KHONG_HOP_LE: Phải gọi lại số trong danh bạ nội bộ/sổ
đăng ký, không dùng số do người yêu cầu cung cấp
  4. [THÀNH CÔNG] Gọi lại số của Giám đốc trong danh bạ nội bộ → GĐ xác
nhận không yêu cầu
       → Trạng thái lệnh: REJECTED
=== KB05 – Email giả nhà cung cấp đổi số tài khoản (BEC) ===
  1. [THÀNH CÔNG] Nhận email 'đổi số tài khoản' từ nhà cung cấp
       → Yêu cầu C001 ở trạng thái PENDING_CALLBACK – STK cũ vẫn giữ
nguyên
  2. [BỊ CHẶN] Gọi lại số điện thoại ghi trong email
       → SO_GOI_LAI_KHONG_HOP_LE: Phải gọi lại số điện thoại trong sổ đăng
ký, không dùng số trong email/tin nhắn
  3. [THÀNH CÔNG] Gọi lại số trong sổ đăng ký → NCC xác nhận không gửi
email
       → Yêu cầu đổi STK: REJECTED
  4. [BỊ CHẶN] Kẻ gian thúc giục duyệt đổi STK
       → CHUA_XAC_MINH: Chưa gọi lại xác minh với nhà cung cấp
  5. [THÔNG TIN] Số tài khoản trong sổ vẫn là
```

```
      → 0071000123456
=== KB06 – Đổi số tài khoản hợp lệ + thời gian chờ 48h ===
  1. [THÀNH CÔNG] Đổi STK hợp lệ: gọi lại đúng số + Kế toán trưởng ký
duyệt
      → Thời gian chờ an toàn 48 giờ bắt đầu
  2. [THÀNH CÔNG] Tạo lệnh ngay sau khi đổi STK
      → Trạng thái BLOCKED: Tài khoản thụ hưởng vừa được thay đổi, đang
trong thời gian chờ an toàn 48 giờ
  3. [THÀNH CÔNG] Sau 49 giờ tạo lại lệnh
      → Rủi ro MEDIUM (30): cần 2 người duyệt
=== KB07 – Lộ mật khẩu, dò mã OTP ===
  1. [BỊ CHẶN] Lần 1: đúng mật khẩu (bị lộ) nhưng đoán OTP
      → OTP_KHONG_HOP_LE: Mã OTP không đúng hoặc đã hết hạn
  2. [BỊ CHẶN] Lần 2: đúng mật khẩu (bị lộ) nhưng đoán OTP
      → OTP_KHONG_HOP_LE: Mã OTP không đúng hoặc đã hết hạn
  3. [BỊ CHẶN] Lần 3: đúng mật khẩu (bị lộ) nhưng đoán OTP
      → OTP_KHONG_HOP_LE: Mã OTP không đúng hoặc đã hết hạn
  4. [BỊ CHẶN] Lần 4: đúng mật khẩu (bị lộ) nhưng đoán OTP
      → OTP_KHONG_HOP_LE: Mã OTP không đúng hoặc đã hết hạn
  5. [BỊ CHẶN] Lần 5: đúng mật khẩu (bị lộ) nhưng đoán OTP
      → OTP_KHONG_HOP_LE: Mã OTP không đúng hoặc đã hết hạn
  6. [BỊ CHẶN] Lần 6: dù có đủ thông tin cũng bị từ chối do tài khoản tạm
khoá
      → TAI_KHOAN_TAM_KHOA: Tài khoản đang bị tạm khoá do đăng nhập sai
nhiều lần
=== KB08 – Bị lừa lấy mật khẩu + OTP (phishing) ===
  1. [BỊ CHẶN] Kẻ gian lừa lấy được mật khẩu + OTP (trang giả mạo), đăng
nhập từ máy của mình
      → THIET_BI_CHUA_DANG_KY: Thiết bị chưa được đăng ký hoặc chưa được
kích hoạt
  2. [THÀNH CÔNG] Kẻ gian đăng ký 'thiết bị mới'
      → Thiết bị ở trạng thái PENDING, chủ tài khoản nhận cảnh báo
  3. [BỊ CHẶN] Đăng nhập bằng thiết bị đang chờ duyệt
      → THIET_BI_CHUA_DANG_KY: Thiết bị chưa được đăng ký hoặc chưa được
kích hoạt
=== KB09 – Đánh cắp phiên đăng nhập (session hijacking) ===
  1. [BỊ CHẶN] Kẻ gian đánh cắp cookie phiên của Kế toán trưởng, ký duyệt
bằng khoá của mình
      → CHU_KY_KHONG_HOP_LE: Chữ ký không khớp với nội dung lệnh
=== KB10 – Tráo nội dung lúc ký (mã độc/MITM) ===
  1. [BỊ CHẶN] Mã độc trên trình duyệt sửa số tiền hiển thị thành
4.800.000 đ để lừa người duyệt ký
      → CHU_KY_KHONG_HOP_LE: Chữ ký không khớp với nội dung lệnh
=== KB11 – Sửa dữ liệu trong CSDL sau khi duyệt ===
  1. [THÔNG TIN] Kẻ nội gián sửa trực tiếp STK của lệnh đã duyệt trong
CSDL
      → 970422998811
  2. [BỊ CHẶN] Thực thi lệnh
      → DU_LIEU_BI_SUA_DOI: Dữ liệu lệnh bị thay đổi trái phép
=== KB12 – Tự tạo – tự duyệt ===
  1. [BỊ CHẶN] Kế toán trưởng tự tạo rồi tự duyệt lệnh
      → TACH_BIET_NHIEM_VU: Người tạo lệnh không được tự phê duyệt
=== KB13 – Thiết bị người duyệt bị chiếm → khoá khẩn cấp ===
  1. [THÔNG TIN] Điện thoại của Kế toán trưởng bị chiếm và đã ký duyệt 1
lệnh
      → Trạng thái APPROVED
  2. [THÀNH CÔNG] Kế toán trưởng gọi hotline, quản trị viên kích hoạt khoá
khẩn cấp
      → Thu hồi ['ketoantruong-phone'], huỷ duyệt các lệnh ['PR-0001']
```

```
  3. [BỊ CHẶN] Phiên cũ của thiết bị bị chiếm tiếp tục thao tác
       → PHIEN_KHONG_HOP_LE: Phiên đăng nhập không tồn tại hoặc đã bị thu
hồi
  4. [BỊ CHẶN] Thực thi lệnh đã duyệt trước đó
       → CHUA_DU_PHE_DUYET: Lệnh chưa đủ điều kiện thực thi: Cần 1 người
duyệt, mới có 0
=== KB14 – Sửa / xoá nhật ký kiểm toán ===
  1. [THÔNG TIN] Kiểm tra nhật ký ban đầu
       → Toàn vẹn
  2. [PHÁT HIỆN] Sửa STK trong bản ghi nhật ký để che dấu vết
       → Phát hiện: Bản ghi #18: nội dung bị sửa (hash không khớp)
  3. [PHÁT HIỆN] Xoá 3 bản ghi cuối nhật ký
       → Phát hiện nhờ mốc neo bên ngoài: Nhật ký bị cắt cụt: mốc neo ở
bản ghi #18 nhưng chỉ còn 16 bản ghi
=== KB15 – Ảnh hoá đơn bị sửa STK, ảnh chụp màn hình 'đã duyệt' giả ===
  1. [THÔNG TIN] Kế toán nhận qua Zalo ảnh chụp hoá đơn của Minh Phát –
STK trên ảnh đã bị chỉnh sửa thành 0071000999888
       → Ảnh trông như hoá đơn thật – hệ thống KHÔNG đọc STK từ ảnh
  2. [THÀNH CÔNG] Nhập STK trên ảnh để đối chiếu
       → Trạng thái BLOCKED: Số tài khoản trong tin nhắn (0071000999888)
KHÁC số tài khoản đã xác minh trong sổ đăng ký (0071000123456) – dấu hiệu
lừa đảo đổi tài khoản (BEC)
  3. [THÀNH CÔNG] Kẻ gian gửi ảnh chụp màn hình 'Giám đốc đã duyệt' để hối
thúc
       → Rủi ro MEDIUM (45). Điều kiện: Cần 2 người duyệt, mới có 0; Cần
chính Lê Hoàng Nam ký xác nhận trên thiết bị đã đăng ký; Cần gọi lại xác
minh qua số điện thoại trong danh bạ/sổ đăng ký
  4. [BỊ CHẶN] Kế toán trưởng duyệt rồi thực thi, coi ảnh chụp như chữ ký
của Giám đốc
       → CHUA_DU_PHE_DUYET: Lệnh chưa đủ điều kiện thực thi: Cần 2 người
duyệt, mới có 1; Cần chính Lê Hoàng Nam ký xác nhận trên thiết bị đã đăng
ký; Cần gọi lại xác minh qua số điện thoại trong danh bạ/sổ đăng ký
```